

Warsaw, November 12, 2024

Decision

DKN.5130.2415.2020

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572), Article 7(1) and (2), Article 60, Article 101, and Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57(1)(a) and (h), Article 58(2)(i), Article 83(1) – (3), and Article 83(4)(a) in connection with Article 24(1), Article 25(1), Article 28(1) and (3), and Article 32(1) and (2), and also Article 83(5)(a) in connection with Article 5(1)(f) and Article 5(2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), after conducting an ex officio administrative procedure regarding the violation of personal data protection regulations by A. based in W. at ul. (...) and X. based in W. at ul. (...), the President of the Personal Data Protection Office

1) stating the violation by A. based in W. at ul. (...) of Article 24(1), Article 25(1), Article 28(1), and Article 32(1) and (2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as "Regulation 2016/679," consisting of:

a) the failure to implement appropriate technical and organizational measures to ensure the security of data processing in information systems and the protection of the rights of data subjects, based on a risk analysis considering the state of technical knowledge, the cost of implementation, the nature, scope, context, purposes of processing, and the risk of infringement of the rights or freedoms of natural persons,

b) the failure to implement appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of personal data processed in information systems, particularly regarding vulnerabilities, errors, updates, and their possible consequences for these systems and the actions taken to minimize the risk of their occurrence, resulting in a violation of the principle of confidentiality (Article 5(1)(f) of Regulation 2016/679) and the principle of accountability (Article 5(2) of Regulation 2016/679),

c) the lack of verification of the data processor to ensure sufficient guarantees for the implementation of appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679 and protects the rights of data subjects,

imposes on A. based in W. at ul. (...), for the violation of Article 5(1)(f), Article 5(2), Article 25(1), Article 28(1), and Article 32(1) and (2) of Regulation 2016/679, an administrative fine in the amount of 1,527,855.00 PLN (in words: one million five hundred twenty-seven thousand eight hundred fifty-five zlotys);

2) stating the violation by X. based in W. at ul. (...) of Article 32(1) and (2) and Article 32(1) and (2) in connection with Article 28(3)(c) and (f) of Regulation 2016/679, consisting of the failure to implement appropriate technical and organizational measures to ensure the security of personal data, including ensuring their confidentiality, imposes on X. based in W. at ul. (...), for the violation of Article 32(1) and (2) and Article 32(1) and (2) in connection with Article 28(3)(c) and (f) of Regulation 2016/679, an administrative fine in the amount of 20,037.00 PLN (in words: twenty thousand thirty-seven zlotys).

Justification

A. (ul. (...), (...)), hereinafter referred to as "A.", "the Company" or "the Administrator," on April 24, 2020, reported to the President of the Personal Data Protection Office, hereinafter also referred to as

“the President of UODO” or “the supervisory authority,” a personal data breach that occurred on April 17, 2020 (a supplementary notification was submitted to the supervisory authority on May 7, 2020). The President of UODO conducted an explanatory procedure regarding the reported personal data breach and then, on April 27, 2020, initiated an ex officio administrative procedure regarding the possibility of A. violating Article 5(1)(f), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679.

By letters dated March 15, 2021, and June 15, 2021, the President of UODO informed X. (ul. (...), (...)), hereinafter referred to as “X.” or “the Data Processor,” of the recognition of X. as a party to the administrative proceedings conducted under the reference number DKN.5130.2415.2020, indicating that the subject of this proceeding is the possibility of A. and X. violating the obligations arising from the provisions of Article 5(1)(f), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679.

In connection with the submitted explanations, on March 24, 2022, r. The President of the UODO has expanded the proceedings under reference number DKN.5130.2415.2020 to include the possibility of a breach of obligations arising from the provisions of Article 28(1) and Article 28(3) of Regulation 2016/679.

In a letter dated April 17, 2024, the President of the UODO informed A. and X. that the proceedings under reference number DKN.5130.2415.2020 have been expanded to include the possibility of a breach of obligations arising from Article 5(2) of Regulation 2016/679.

The President of the UODO, as a result of the conducted explanatory proceedings and administrative proceedings, established the following factual state.

I.

In the report of the personal data breach, the Administrator described that the breach consisted of the fact that “(...) during the process of launching a new website on April 17, 2020, files from the old website were copied to a new folder that should have been hidden but was made accessible. This was done by an employee of the IT company without prior consultation and verification of the contents of the files from the old website. The IT company employee made a mistake and did not hide the files. Company A. was not aware of this action (...)”. In a supplementary report, A. indicated that “(...) the breach consisted of the possibility of accessing the historical database file (not in use) of the site (...). The breach occurred due to allowing the indexing of the database files of the old site (...) by the Z. robot. The possibility of indexing the files was caused by improper configuration by the IT company responsible for the ongoing maintenance of the IT infrastructure. (...) The scale of the breach was also smaller than originally thought, affecting PESEL numbers of individuals (it concerned over 7,000 fewer individuals than those included in the database). The breach regarding the possibility of accessing customer data included only first name, last name, email address, residential address, encrypted password for the Client panel of the site (...) and phone number concerned over 7,000 individuals [without PESEL number] (...) From the independent audit of the incident commissioned by company A., it follows that the main reason for the indexing of the files from the old website was errors in the configuration file (...). The old website (...) contained backup copies of the database placed there by the IT company and not removed during maintenance work (...)”.

From the information contained in the "Notification of Personal Data Breach" forms submitted to the supervisory authority, it follows that: - there was a breach of data confidentiality, - the cause of the personal data breach was an unintended internal action, - the approximate number of individuals affected by the breach is 21,453 (cf. notification of personal data breach from May 7, 2020), - the categories of personal data that were breached include: first name and last name, residential or temporary address, PESEL number, date of birth, email address, phone number, and encrypted password for registration on the site (...), - the breach concerns personal data of customers and employees of A.

The Administrator, along with a letter dated June 3, 2020, provided the supervisory authority with the document: “Report (...)”. It should be noted that the discussed document was prepared at the request

of the Administrator. The supervisory authority did not find grounds to question the credibility of this evidence.

As indicated in its content, the purpose of the report was to present how the security incident occurred in the IT environment of A. resulting in the disclosure of legally protected information (including personal data of A.'s customers, their PESEL numbers, residential addresses, email addresses, phone numbers) and information constituting business secrets (including password hashes, certificates, security keys for selected IT systems). The purpose of the report was also to indicate the causes of the disclosure of the above information. The report outlined the principles of conducting work related to the analysis of the incident, a description of the incident, a description of the Administrator's IT environment in relation to the incident, a description of how the incident occurred, the scope of the incident, and the causes of the incident that occurred.

In the section indicating the scope of the incident, it was stated that "(...) information in the databases was disclosed or could have been disclosed (...) access to database dumps [their reading was possible due to the lack of appropriate permissions prohibiting reading and due to the lack of encryption] occurred on April 17-20, 2020 (...) the number of rows in the customer table: 21,453. This is the number of unique records. Each record should be treated as one customer and the personal data assigned to them according to the above scheme (...)". The report also indicated a list of IP addresses that downloaded the indexed content.

In the section indicating the causes of the incident, technical and organizational causes were discussed. The technical causes indicated were: (...). The organizational causes indicated were: (...).

II.

The supervisory authority received explanations from the Administrator and the Data Processor regarding their cooperation related to the processing of personal data. The Administrator, along with a letter dated June 3, 2020, provided the President of the UODO with a copy of the agreement (...), which was concluded between A. and X. The agreement contains a number of provisions regarding the relationship between the Administrator and the Data Processor. From the perspective of this case, the key provisions in this agreement are formulated as follows: - "(...) The parties concluded the agreement on July 31, 2019 (...) ["Main Agreement"] (...)", - "(...) The implementation of the Main Agreement requires the Administrator to entrust the Processor with the processing of personal data (...)", - "(...) Personal Data is processed only to the extent provided for in the Entrustment Agreement and the Main Agreement and for the purposes of implementing the Agreement. the computer system and software of A., including supervision of the network computer system, as well as other services specified in this agreement.

The discussed agreement defines what is meant by the term information system and indicates that it is a collection of interconnected elements (a set of computer systems, networks, and software) whose function is to process data using the computer system and software of A., including supervision of the network computer system, as well as other services specified in this agreement.

The agreement contains provisions defining, among other things:

- the subject of the agreement,
- the obligations of the contractor (X.),
- additional provisions,
- liability and its exclusions,
- the entrustment of personal data,
- final provisions.

From the submitted agreement, it follows that its subject is the provision by X. to A. of IT services related to maintaining the proper and uninterrupted functioning of the information system (system) and software of A.

The discussed agreement defines what is meant by the term information system and indicates that it is a collection of interconnected elements (a set of computer systems, networks, and software) whose

function is to process data using the computer system and software of A., including supervision of the network computer system, as well as other services specified in this agreement. computer technology, taking into account changes in this system made during the term of this agreement. The content of the agreement specifies the obligations of X., stating that “(...) 1. The obligations of the Contractor [X.] include ongoing IT support and supervision of the IT System owned by the Client [A.], through the provision of services consisting of: 1) Ensuring continuous support for system users, including but not limited to providing IT supervision, troubleshooting technical, system, and software failures, maintenance of computer hardware and software, handling Client's requests; 2) Ongoing management (administration) of the IT System, monitoring the IT System, with particular emphasis on the security of the Client's system operation; 3) Consultations regarding the current use of the IT System; 4) Performing administrative tasks and assignments related to maintaining the system in operation and installing computer hardware, software, and updating system components; 5) Keeping documentation of the IT system, inventorying components; 6) Preparing and implementing a unified IT policy, data security, and IT governance; 7) Supplying hardware, software, IT solutions along with installation and configuration as agreed and at the request of the Client; 8) Advising on IT implementation, selection of solutions, and managing IT projects; 2. The detailed scope of the Contractor's obligations is defined in Appendix No. (...) to the Agreement [Offer] (...)”.

In the part of the agreement defining liability and its exclusions, it was indicated, among other things, that “(...) The Contractor will make every effort to ensure the highest quality of services provided and will perform all entrusted tasks to the best of his knowledge, taking into account the professional nature of his activities (...) The Contractor is not responsible for the correctness of the operation of systems implemented by third-party companies. The Contractor will also not be liable in the event of failures of components of systems that are products of third-party companies, e.g., computer hardware, workstation software, network operating systems, task systems, unless the failure is related to the Contractor's interference with these elements of the IT System carried out in the performance of this agreement. The Contractor does not provide any guarantees regarding the correctness of the operation of the system or its components implemented at the Client's before signing the below agreement, excluding those previously implemented by the Contractor (...) The Contractor is not liable for damages resulting from: 1) errors caused by improper use of the system by the Client's users resulting in data loss, significant slowdown of system operation, or system stoppage; 2) data loss due to system failure or accidental deletion of data by the system user; 3) malicious software activity; 4) breach of security or exceeding permissions by the Client's system users; 5) unauthorized access to the system by unauthorized persons due to configuration errors or security deficiencies; 6) sharing passwords by system users with unauthorized persons intentionally or through negligence; 7) loss of data or access to data due to hardware or software failure, unless the failure occurred due to reasons concerning the Contractor; 8) actions of external factors independent of the Contractor, including but not limited to electrical power supply, external environment, air conditioning, lack of Internet access, WAN, lack of connection to external systems, cloud services managed by third parties, and errors in the security of software from other suppliers operated by the Client; The Contractor's liability, as mentioned above, is excluded to the extent that the Contractor is not liable for its occurrence (...)”.

The agreement contains a provision regarding the entrustment of personal data. It states that the principles of entrusting the processing of personal data are regulated by a separate agreement of the parties (the entrustment agreement has already been discussed in detail above). Explanations regarding the cooperation between A. and X. were also provided by the Data Processor. In a letter dated July 15, 2021, X. indicated that he provided IT support services for A. from July 31, 2019, to September 30, 2020, and performed duties related to providing ongoing care for the maintenance and functioning of the IT system.

III. The Administrator submitted explanations regarding the verification of the Data Processor before establishing a relationship with it concerning the obligation of the Data Processor to provide sufficient guarantees of implementing appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679. In a letter dated February 3, 2021, the Administrator

explained that the verification of the Data Processor took into account the following circumstances: 1) The Data Processor had previously collaborated with the Company, and during the earlier cooperation, the Company did not find any reservations regarding the quality of work performed, nor any other issues related to the processing of personal data or matters concerning information security or managed IT systems; 2) The Data Processor declared having a current certificate of implementation of the ISO/IEC 27001 standard regarding information security (certificate number (...))

The Company verified and confirmed the truthfulness of such a declaration, 3) The Data Processor had the status of a certified partner of the largest global companies offering cybersecurity solutions (such as: (...)), as well as being a certified partner of global giants providing IT solutions with the highest level of IT security ((...)), 4) The Data Processor has been operating in the market since (...), serving over (...) clients at the time of submitting the offer and collaborating with over (...) IT and telecommunications security experts, 5) Before making a decision to continue cooperation, the Company verified the competencies of the team dedicated by the Data Processor to work with the Company, including within the framework of negotiating the terms of cooperation, the Company required the Data Processor to submit the following declarations and undertake the following commitments: - The Data Processor committed that "it will make every effort to ensure the highest quality of services provided and will perform all entrusted activities in accordance with its best knowledge, taking into account the professional nature of its activities," - "The Processor, taking into account the state of technical knowledge, the cost of implementation, as well as the nature, scope, context, and purposes of processing and the risk of infringement of the rights or freedoms of natural persons of varying probability and severity of threat, has implemented appropriate technical and organizational measures in accordance with the purpose of executing the Proper Agreement," - The subject of the contractor's work included, among others, "Current management (administration) of the IT System, monitoring of the IT System, with particular emphasis on the security of the Client's system" and "Consulting in the field of computerization, selection of solutions, conducting IT projects"; - The Contractor committed to "exercise due diligence to ensure and maintain appropriate security measures to protect Confidential Information from access and unlawful use by unauthorized persons" under the penalty of a contractual fine of 100,000 PLN; - The Data Processor declared that an advantage of cooperating with it is, among others, "the transfer of responsibility for the entire IT infrastructure and user support to one entity."

IV. The President of the UODO, in a letter dated August 27, 2020, addressed A. with a question of whether the Administrator exercised the right of control referred to in Article 28(3)(h) of Regulation 2016/679, in terms of ensuring by X. the measures required under Article 32 of Regulation 2016/679, and if so, to indicate when, how, and what the results of such control were. The supervisory authority also requested the submission of copies of the relevant documentation. In response to such a question, A. in a letter dated September 7, 2020, indicated that "(...) regular testing, measuring, and assessing the effectiveness of the organizational and technical measures aimed at ensuring the security of personal data processing in the IT area was partially entrusted to company X. as part of the overall cooperation of the Administrator. These activities included reviews of reports from the tools used, analyses and decisions related to additional security, or examining the vulnerability of the IT infrastructure in terms of the occurrence of the TOP10 OWASP vulnerabilities (report attached to the letter dated June 3, 2020)."

V. The Administrator provided explanations regarding the principles – applicable before the occurrence of the personal data breach – of conducting regular testing, measuring, and assessing the effectiveness of the technical and organizational measures aimed at ensuring the security of the personal data processed in the IT systems subject to the breach. In a letter dated June 3, 2020, the Administrator informed that regular testing, measuring, and assessing the effectiveness of the technical and organizational measures aimed at ensuring the security of the processed data in the IT area was entrusted to X. as part of the overall service of the Administrator, additionally attaching to the explanations a copy of the data processing entrustment agreement dated July 31, 2019, and a summary of sample activities related to testing, measuring, and assessing the effectiveness of the technical and organizational measures and their results. In turn, in a letter dated February 3, 2021, the

Administrator indicated that as part of regular testing, measuring, and assessing the effectiveness of the security measures related to the functioning of the previous website (...), activities were carried out, such as entrusting X. with conducting regular security tests in accordance with the list of activities contained in the offer and in the data processing entrustment agreement, as well as conducting a security analysis, the report of which was attached to the explanations. The Administrator informed that "(...) these activities also included reviews of reports from the tools used, analyses and decisions related to additional security, or examining the vulnerability of the IT infrastructure (...)."

VI. A key issue from the perspective of the subject matter of the personal data breach is the involvement of the Data Processor in the process of transferring the website available at the address (...) from the current hosting service provider directly to A.'s infrastructure. It should be noted at the outset that the Administrator considers X. to be responsible for the situation that has arisen, while the Data Processor expresses an opposing position and indicates that it did not have the necessary information that it should have received from the Administrator. In order to accurately establish the factual state, the President of the UODO addressed both the Administrator and the Data Processor. processing entity to provide detailed explanations regarding the transfer of the existing website to a new environment. In a letter dated February 3, 2021, A. explained that "(...) the transfer of the existing website to the new environment was carried out in connection with the execution of the main agreement by . The scope of obligations was indicated in the main agreement in paragraph 2 and in the offer prepared for A. (...) Additionally, according to explanations obtained after the event, the processing entity confirmed that the event occurred as a result of an error by their employee (...)[original spelling]."

In the aforementioned letter, the Administrator also indicated that they entrusted the Processing Entity with verifying whether the locations where the copies of the database are stored were configured in a manner ensuring their confidentiality, to which they received information from X. that the copies of the databases were made in accordance with the requirements of the data processing entrustment agreement and with the provision of an appropriate level of security. Based on this, the Administrator assumed that "(...) the entirety of tasks in the area of security and confidentiality of data carried out by the specialized processing entity provides sufficient guarantees for the protection of customer data (...)." The Administrator concluded that there was no need to engage another entity to supervise the actions taken by X., while the Administrator themselves supervised the work undertaken and the results within the framework of quarterly IT status reviews.

X. provided explanations in this regard in a letter dated July 15, 2021. The explanations from the Processing Entity confirm that the transfer of the aforementioned website was carried out by X. within the framework of the applicable agreement. The Processing Entity indicated that its task was to prepare the operational environment. X. chose for this "(...) the latest version of software C. available at that time and a commercial license for the current version of a renowned operating system for hosting (...)", and also equipped the server with software D., which was placed in a dedicated VLAN in private addressing. The transfer of the Administrator's website was carried out by making copies of the databases to the website folder and copying the entire folder structure along with the content to the newly prepared (according to the Administrator's instructions) server. X. conducted preliminary inspections and informed the Administrator that the website was built using an outdated content management system and that it had not been updated. In this regard, a recommendation was issued regarding the necessary update. The Processing Entity indicated that it was not authorized to undertake such actions, did not have the necessary accesses, and that conducting the update was not the subject of the concluded service agreement. The above notifications were made orally during periodic meetings in the presence of the President of the Management Board, the Marketing Director, the Data Protection Officer, and a representative of the Administrator's IT Department. During these meetings, the Processing Entity repeatedly received information that work on the new website was nearing completion, and that the old one would soon be deactivated.

The Processing Entity informed that it did not receive from the Administrator information about the functionalities of the website (...) (including that it implements a reservation process and that it itself is

a collection of personal data). It also did not have information that the database of the website is used for processing personal data and that this data is not transmitted to the local enterprise management system. Additionally, X. indicated that in the data processing entrustment agreement concluded between the parties, the website (...) was not specified in terms of personal data processing. He also pointed out that he did not receive any guidelines from the Administrator regarding the control of the website's security considering the personal data processed by it. X. also explained that he informed the Administrator that his website is based on outdated software, and that it should have a substantive guardian who would ensure oversight of its operation. Additionally, the Processing Entity informed that it recommended to the Administrator the implementation of a class Q solution for automatic log analysis and event correlation, which could enable monitoring, among other things, the logs of the web server. The Processing Entity also indicated that the Administrator informed him that the transfer of the website to A.'s infrastructure is temporary due to the change of service provider, and that the old website would be replaced by a new one, while simultaneously commissioning the Processing Entity for ad hoc actions, e.g. "(...) related to the loss of files on the website after a probable breach of it (...), related to an attack on the unsecured form of the website (...), or explanations regarding exceeding limits in the G. service and blocking addresses that are exhausting the G. hosting service (...)".

According to X.'s explanations, at the end of February 2020, A. informed the Processing Entity that the new website was ready and commissioned him to launch it on the server that had been servicing the old website. X. conveyed to the Administrator that in his opinion, security measures should be taken and OWASP TOP 10 security tests should be conducted. The tests were carried out from March 19 to March 29, 2020, and concluded with the preparation of a report. As a result of the tests conducted, the Processing Entity made changes that increased the level of security of the server. Additionally, the Processing Entity indicated that it actively collaborated with the author of the OWASP report, the authors of the new website, and the author of the API on the implementation of the recommendations of the report. The report in question – as X. indicates – is significant due to the fact that security tests of the new website were conducted.

from any agreement between the parties.

In March 2020, on the same server that was already being used to host the old website, the focus was on verifying the correctness of the server configuration and its web services. The data processor also indicated that "(...) Company [X.] accepted the order to transfer the website (...) from G. to the server it managed, without having information about the scope of processing carried out using the website (...), considering that it was dealing with a website of an informational nature, whose database serves to support the CMS of the website, i.e., displaying its content, and through it, there is no processing of personal data related to the provision of services by A. A. never indicated that the website had been processing data of its clients for many years, saving it in the CMS database, and that the mentioned database was located in the environment of the website. In this regard, the Company - lacking information in this area provided by the data administrator (A.) - applied security measures and a methodology for supporting the web server, appropriate for the nature and scope of the website's operation, in accordance with the knowledge possessed and the instructions provided by A. (...)".

In response to the question from the President of UODO regarding how the verification of the server logs of O., on which the website (...) was located, was conducted, X. indicated that it used the hosting system L. and did not perform manual checks of the configuration file of O., as this file was entirely managed by L. and, according to the manufacturer's indication, the data processor used only functionalities available in the graphical interface. According to X.'s explanations, manual monitoring of logs was not performed due to the lack of appropriate orders from the Administrator and the high time expenditure, which the data processor did not have.

In response to the question regarding the procedures for reviewing the network and application infrastructure for potential breaches of the Administrator's website security, X. informed that it conducted periodic monitoring of the website using the W. system, reviewed logs, and had implemented policies configured to ensure automatic blocking of traffic to/from hosts that exceeded the configured rules. The data processor explained that it recorded anomalies in internal network traffic

using antivirus software, which was installed on all servers and workstations. The control was carried out once a week or immediately after an event was registered. To enable monitoring of the system infrastructure, X. provided the Administrator with a commercial system designed for this purpose, through which system updates of P., server replication, AD replication, and other environmental conditions of the infrastructure were monitored.

The data processor also informed that the database was not encrypted and until the incident occurred, it did not know its contents. X. considered that the database of the website served to support the display of information on the website and decided against its encryption, deeming it unnecessary. X. stated that it did not separate the management network, i.e., the network used for managing telecommunications. The server had one network interface and one IP address, which handled both the production traffic of the server and its management. The data processor deemed that a separate management was not necessary for this server; however, other methods of protecting access to server management were implemented within the standard security measures that had been previously applied by X. in preparing the server for hosting tasks. X. indicated that manual aliases were not set up, nor were subdomain aliases created. The configuration was performed automatically by L.'s scripts. The data processor indicated that it conducted system reviews, resulting in reports and recommendations, which were presented at monthly meetings with the Management Board of A.

In a letter dated July 15, 2021, X. responded to the claims made by A. contained in the previously submitted explanations and documents that the Administrator presented to the supervisory authority. X. indicated that "(...) it is not true that a configuration error was made, which the Company admitted to A. on the day the incident was detected; rather, it is true that there was a hasty and, as it turned out, incorrect interpretation of the information provided by V., and such an erroneous response was formulated to IODO A. on April 24, 2020 (...)" The data processor addressed the conclusions of the Report (...). In response to the indicated causes of the incident mentioned in the report: "(...) From the beginning of April 2020, there was a lack of regular and routine verification of the logs of server O. by Y. and a lack of standard responses to attempts to breach security. Routine log reviews would have detected attempts at attacks and non-standard attempts to index the server's content by (...) (or an intruder) as early as April 9, 2020, and the appropriate de-indexing entry in N. would have prevented the disclosure of already indexed content (...)" X. polemically indicated that "(...) to quickly find threats in the logs, they should have been reviewed daily. The Company [X.] did not have such capability within its basic responsibilities, as it did not possess a tool that would allow for the automation of these tasks [even though it recommended that A. implement such a tool regarding all logs generated by elements of the IT infrastructure] and did not have the time for their manual execution. It should be emphasized that undertaking such actions was not commissioned by A. at any stage of cooperation, nor was there an obligation to undertake such actions arising from any agreement between the parties."

from the content of the agreement. The offer presented by A. for the provision of services was calculated without taking into account the performance of such activities, of which the Company [X.] was also unaware at the time of submitting the offer / concluding the agreement (at that time, the website was located in G.). Attempts to breach security were only visible in selected periods in the logs of O. and possibly in the logs of R., so their review should also have been handled by the webmaster, whom the Administrator did not appoint. If A. had provided the Company with information regarding the functional nature of the website, the content of the database, and the manner and scope of the data processed therein, the Company [X.] would have had the opportunity to establish additional protection rules with the Administrator or implement tools in the Administrator's infrastructure that would allow for their enforcement (...).

Regarding the statement contained in the aforementioned report: "(...) The transfer of the website from the G. service to the server (...) by Y. without verifying the vulnerabilities of the transferred website. Even a basic verification of the version of the website would indicate the R. framework in a version below (...), which is susceptible to executing external scripts and breaching security. Additionally, the lack of verification of the transferred website necessitates the scaling of infrastructure capable of

handling queries, a significant portion of which are bots or traffic exploiting vulnerabilities of the website. This translates into increasing the cost of maintaining the solution and the choice of suboptimal solutions [e.g., C. while simultaneously disabling proxy traffic] (...)” The data processor indicated that “(...) The Company was not obliged to conduct a security analysis of the components used in the website, as it received only an instruction from the Administrator to transfer it. Nevertheless, the Company informed the Administrator in the period preceding its transfer that the website required updates, while their execution was not within the scope of the Company's obligations arising from the Agreement with A. (...)”.

VII.

In connection with the existing discrepancies between the explanations of the Administrator and the Data Processor, on August 30, 2021, the President of UODO directed a request to A. and X. to provide explanations regarding the indication of the direct cause of the improper configuration that led to the breach of personal data protection. In a letter dated September 6, 2021, which was a response to the aforementioned request from the President of UODO, the Administrator indicated that the direct cause of the incident that led to the breach of personal data protection was a server configuration error, which resulted in the possibility of indexing files located on the server by indexing robots. In response to the aforementioned request, in a letter dated September 7, 2021, the Data Processor explained that in its opinion “(...) the situation that occurred was not a consequence of an improper server configuration nor a consequence of actions for which it was obliged to carry out (...)”. The Data Processor indicated that, in its opinion, the irregularities could have resulted from the failure of the Administrator to provide it with information about the actual purpose of the system and databases, preparing only the default configuration of the hosting panel provided by its manufacturer, without conducting its configuration taking into account the specifics of the processed data, and operating an outdated content management system for the needs of the website. X. emphasized in the aforementioned letter that the cause of the incident was not an improper server configuration, as no element of the configuration of O. or the server enabled the installation of exploits. The Data Processor reiterated that due to the lack of guidelines from the Administrator, it independently adopted and applied protective measures that, in its opinion, were commensurate with the known nature of the website.

VIII.

The President of UODO summoned A. on September 27, 2021, to present evidence confirming that the Data Processor was responsible for the occurrence of the incident. In response to the aforementioned request, in a letter dated October 6, 2021, the Administrator explained that the Data Processor was carrying out the order to transfer the website located at (...) from the current hosting service provider to a server in the infrastructure of A. as part of the activities specified in the agreement dated July 31, 2019. Under the aforementioned agreement, the Data Processor was responsible for, among other things, advising on computerization, selecting appropriate solutions, and conducting IT projects. The scope of duties was defined in an annex to the agreement and included: - proactive control of the information system, - security and event analysis, - conducting IT projects for the computerization of business processes, IT consulting regarding the provision and selection of IT tools, - protection of data processing, penetration testing, threat and risk analysis, - monitoring system events related to data processing, implementing dedicated solutions. The Administrator emphasized that in the scope of the aforementioned tasks, the Data Processor was obliged to safely, correctly, and error-free execute the commissioned and accepted service. The Administrator indicated that X. had the responsibility to analyze logs in such a way as to allow for ongoing monitoring to ensure that no anomalies occurred during the tasks being performed that could threaten the information security of the Administrator. The Administrator also indicated in the aforementioned letter that “(...) the explanations of the Data Processor regarding its ignorance that the website (...) is also a dataset are irrelevant to this proceeding, as the key fact in the matter is the erroneous execution by the Data Processor...”

server configuration, which consequently allowed the disclosure of data contained in the website files to unauthorized persons. The fact that this data was personal data is a secondary issue [although, due to the nature of this data, it is extremely sensitive and of very high significance], as one should never

allow the indexing of any website files without any control and awareness, regardless of their content. Furthermore, it should be noted that the processor's translation regarding the lack of knowledge about the website's content further indicates the lack of due diligence on the part of the processor, who carried out the transfer of the website without having sufficient information to perform these actions correctly and safely for the administrator. It is the processor who should take the necessary steps to sufficiently determine what is the subject of the transfer, and in the absence of sufficient information, assess the risk and possibly refuse to carry out the order. However, it should be emphasized again that even if the processor had knowledge that the website files contained personal data [although it should have this knowledge] - it would not change the circumstances of the erroneous configuration performed by the processor (...) The processor, as a professional and an entity entrusted with the care of all the administrator's systems, had the obligation to analyze logs in such a way as to continuously monitor whether any anomalies occurred during the tasks performed that could threaten the IT security of the administrator. The burden of selecting such monitoring solutions lay with the processor, so as to adequately and sufficiently identify potential risks and threats. The processor's explanation that it did not have the appropriate time and human resources to properly analyze the logs cannot be considered a valid justification, as the organization of work of the processor is its internal matter, and the administrator had the right to expect services to be performed properly (...).

IX. The President of the UODO summoned the Administrator to provide information on whether it had conducted a risk analysis to ensure an appropriate level of security corresponding to that risk in accordance with Article 32(1) and (2) of Regulation 2016/679 and whether it informed the Processor that the transfer of the website (...) from the previous hosting service provider to a server in the A. infrastructure was related to the processing of personal data of clients. In response to the above summons, on April 25, 2022, the Administrator informed that it had not conducted a risk analysis, indicating that "(...) in accordance with the obligation assumed under § (...) paragraph (...) of the personal data processing entrustment agreement, which is in the files of the relevant case, conducting a risk analysis on behalf of the Administrator was the sole responsibility of the Processor. Given the nature of the service and the professional nature of the Processor, the obligation to analyze the risk associated with taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purpose of processing, as well as the risk of infringement of the rights or freedoms of individuals of varying probabilities of occurrence and significance, related to the transfer of the website from the previous hosting service provider to a server in the A. infrastructure, it was the Processor's absolute obligation to implement appropriate technical and organizational measures ensuring a level of security corresponding to that risk (...)". In the aforementioned letter, the Administrator indicated that the role of the Processor in the organization was to monitor IT systems in a comprehensive and holistic manner and to closely cooperate with the Administrator in the implementation and maintenance of these systems. In the letter, the Administrator informed that "(...) even if the Processor did not know that the data transfer involved personal data, which should fundamentally be considered highly improbable, as a professional it should have exercised due diligence to find out what was covered by the data transfer service to the Administrator's server (...).

X. On May 9, 2022, the President of the UODO sent another letter to the Administrator asking for information on whether the contracts dated July 31, 2019, included website management and the transfer of the website, indicating which software listed in the annex to the data processing entrustment agreement was used for processing the personal data contained on the website (...) and indicating how and when the Administrator commissioned the Processor to transfer the website to the new environment. In response to the above summons, the Administrator informed that the contract for the provision of IT services and the personal data processing entrustment agreement concluded with the Processor undoubtedly included website management, and consequently, the action of transferring the website. The service order was comprehensive and concerned the entire IT area. The Administrator informed that due to the fact that the support of the Processor was very broad and that it was responsible for the IT area, the scope of personal data was defined by indicating the data contained in the specified IT systems. The above, in the opinion of the Administrator, was consistent with the structure of the entrustment agreement, which provided for the specification of the scope,

purpose, and entrusted operations in a separate annex. The scope of processed data using the parties (...) were not broader than the scope of data processed in the indicated IT systems. The Company also indicated that “(...) the data processor, upon accepting the order to transfer the website, was to carry it out with due diligence as a professional in this field. For this purpose, the data processor was granted access to the website (...) in order to properly prepare for the migration [a circumstance confirmed in the explanations provided by the data processor submitted to the UODO in this matter]. It is obvious that one of the circumstances the data processor had to take into account was whether personal data would be processed using the new website [original spelling] (...)”.

XI.

The data processor submitted explanations regarding the actions taken in connection with the increased traffic and exceeding limits on the Administrator's server, informing the Administrator about any effects of the verification actions in this regard, and also provided information regarding its participation in the administration of the website – with an unencrypted database – which was located in the original location. In a letter dated October 4, 2022, the data processor explained that it did not conduct “(...) actions aimed at verifying the manner, scope, or actual processing of personal data. No agreement was concluded between the Company [X.] and A. (...) under which the Company would be [X.] obliged to undertake such actions (...) The Company [X.] fully maintains its previous position in the matter, emphasizing that the process of transferring A.'s IT platform was carried out correctly, safely [in terms of the actions performed by the Company] and free from errors. Working copies of files were prepared for the purposes of migrating the database and files present at the hosting provider (G.), and leaving the aforementioned copies on the server after the completion of the platform transfer process cannot be considered an improper action (...) A copy was also made due to the fact that the correctness of the website's operation after the transfer was to be checked by A. and due to the deletion, shortly after the transfer, of the hosting account by G. [termination of service]. It is also significant in this regard that – according to the information obtained by the Company from A., the website – and consequently, it can be inferred that its database, was used solely for handling content published via the platform, not for storing personal data or any processing thereof and was to be ultimately disabled in a very short time due to the launch of a new website, of which A. informed the Company [which effectively did not happen due to delays in preparing the new service].

The data processor indicated that it selected and applied organizational and technical measures (security) appropriate for the diligent and proper execution of the scope of cooperation – maintaining the operation of the website (...) (informational website) – on the server prepared by X. The data processor raised that 24/7 monitoring of logs was never the subject of the agreement concluded by the parties. Furthermore, X. explained that “(...) similarly, preparing the server [] for the website processing personal data was not included. The website (...) was not on the list of systems or sets of data covered by the personal data processing entrustment agreement or the order regarding their processing (...) The Company [X.] did not have the authority, consent from A., nor the obligation to make any updates to the website's database during its transfer to the new server or after the completion of this process, particularly for the purposes of any potential search for specific database structures [tables] that may contain personal data (...) From the perspective of the proceedings conducted by the UODO, it also seems significant that A. did not inform the Company [X.] during the cooperation about the actual content of the platform [processing personal data through it] and did not take any actions aimed at enabling the Company [X.] to contact the author of the website (...) or the persons servicing this website (despite the fact that the Company [X.] directly requested the provision of contact details) (...)”.

The President of the UODO, in a letter dated September 26, 2022, asked A. to indicate whether the data processor had undertaken verification actions in connection with the aforementioned increased traffic and exceeding limits on the server. In response to the aforementioned letter, on October 5, 2022, the Administrator informed that the data processor did not perform verification actions and, contrary to the obligations arising from the agreements of July 31, 2019, did not monitor or analyze the logs of the www server. The Administrator indicated that the data processor exercised comprehensive care over A.'s IT environment and in many cases acted independently, making ongoing assessments

of what actions were needed or necessary. The Administrator raised that the data processor's explanations are inconsistent because it simultaneously accuses the Administrator of a lack of an agreement that would obligate him to analyze the logs while also indicating that he did not perform the aforementioned analysis because it is not indicated for technical reasons.

XII.

A. presented explanations regarding the introduction of security measures aimed at minimizing the risk of a recurrence of personal data protection violations, which it declared in point 9B of the personal data breach notification. In a letter dated June 3, 2020, the Administrator informed, among other things, that:-

making the processing of personal data more secure.

II. Decision on the elimination of data processing

The Administrator made a decision to completely eliminate the processing of data on temporarily inactive or deactivated websites, updated the procedure for performing and storing backup copies, reviewed the network and application infrastructure for possible vulnerabilities and security breaches, introduced new database encryption standards, verified entries in the configuration file O., decided to implement a new solution for monitoring atypical traffic, hired a person responsible for verifying the implementation of specific technological solutions, and described the principles applied to secure the passwords of individuals affected by the breach.

At the request of the supervisory authority to provide additional explanations regarding the introduction of security measures aimed at minimizing the risk of a recurrence of the personal data breach, the Administrator explained in a letter dated September 7, 2020, among other things, that:

1) verification and analysis of the architecture of the network, systems, and applications had been conducted, and the following conclusions were drawn: - (...)

2) the Administrator made changes regarding the monitoring of atypical traffic in the network by: - (...)

The supervisory authority assessed the evidence for its credibility and evidential value. The President of the UODO considered the evidence submitted by the Administrator and the Data Processor to be credible, as – due to the individual characteristics of this evidence and the objective circumstances of its creation – there are no grounds to question its credibility. At the same time, it should be noted that the positions presented by the Administrator and the Data Processor are contradictory. The lack of consistency in the explanations of the Administrator and the Data Processor primarily concerns the issue of responsibility for the failure to implement technical and organizational measures ensuring security in the process of personal data processing.

During the administrative proceedings, A. attempted to prove that the Data Processor was responsible for implementing adequate measures ensuring security in the process of personal data processing. Conversely, X. indicated that the responsibility for the breach of personal data protection lay with the Administrator. The President of the UODO stated that the evidential value of some documents submitted by the Administrator, in particular the contract (...) concluded between A. and X. and (...) concluded between A. and X., is limited, i.e., some of the evidence submitted by the Administrator (contrary to A.'s position) does not confirm the thesis that the Data Processor received from A. all necessary information regarding the transfer of the website (...), the receipt of which was necessary for the implementation of adequate security measures for the process of personal data processing related to the transfer of the aforementioned website. A detailed justification of the persuasive power of the aforementioned evidence has been included in the reasoning of the decision.

In this factual state, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following:

According to Article 34 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781; hereinafter referred to as the Act of May 10, 2018), the President of the UODO is the competent authority in matters of data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice

to other tasks specified under this regulation, each supervisory authority in its territory monitors and enforces the application of this regulation and conducts proceedings regarding violations of this regulation, including based on information received from another supervisory authority or another public authority.

I. Principles of data processing security.

Article 5 of Regulation 2016/679 formulates principles regarding the processing of personal data that must be respected by all administrators, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (“confidentiality and integrity”). The specification of the confidentiality principle referred to in Article 5(1)(f) of Regulation 2016/679 is provided by further provisions of this legal act. According to Article 5(2) of Regulation 2016/679, the administrator is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance (“accountability”).

According to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity, the administrator implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate this. These measures are reviewed and updated as necessary.

Pursuant to Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity arising from processing, the administrator – both when determining the means of processing and during the processing itself – implements appropriate technical and organizational measures, such as pseudonymization, designed to make the processing of personal data more secure. effective implementation of data protection principles, such as data minimization, and to provide necessary safeguards for processing in order to meet the requirements of this regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679, it follows that the controller is obliged to implement technical and organizational measures that correspond to the risk of infringement of the rights and freedoms of natural persons, with varying probabilities of occurrence and severity of the threat. The provision specifies that when deciding on technical and organizational measures, one must take into account the state of the art, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity. The cited provision indicates that determining appropriate technical and organizational measures is a two-step process.

Firstly, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those resulting from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed.

In the established factual and legal state, the President of the Personal Data Protection Office (UODO) found that there was a breach of personal data protection that occurred as a result of unauthorized access to the customer database file of A. contained on the website (...). This fact is confirmed by the report from the security incident analysis (see point I of the factual justification). As a result of the above, A. violated the principle of confidentiality referred to in Article 5(1)(f) of Regulation 2016/679. The breach occurred due to the indexing of database files by the Z. robot. The process of transferring the website containing personal data from the previous hosting service provider to a new environment was carried out at the request of A. by X.

The controller, in the submitted explanations, informed that he entrusted X. with verifying whether the location where the copies of the database are stored is configured correctly and indicated that he received confirmation from X. that the copies of the databases were made correctly and with the assurance of an appropriate level of security. Based on this information, the Controller assumed that the entirety of the tasks in the area of IT security, carried out by a qualified entity, provides final guarantees for the protection of customers' personal data. It should be emphasized that the Controller, despite having knowledge of how the implementation of changes in the IT system should proceed according to commonly used practices, did not supervise at any stage whether the implementation was proceeding in accordance with commonly applicable standards and the data processing entrustment agreement, despite indicating that he maintained "supervisory and review competencies over the contractor's work results."

The Controller did not take independent actions and did not verify whether the location where the copies of the database are stored is configured in a manner that ensures their confidentiality. According to the explanations provided, the Controller, based on information received from X., assumed that the entirety of the tasks performed by the "specialized entity" in the area of data security and confidentiality provides sufficient guarantees for the protection of customers. As will be justified further in the decision, this improper action by the Controller significantly contributed to the occurrence of a breach of data confidentiality.

The gathered evidence indicates that A. entered into a contract on July 31, 2019 (...). An analysis of the provisions of this contract indicates that X. undertook to provide ongoing support and supervision of A.'s IT systems. The issue of processing personal data related to the execution of the aforementioned contract was regulated by a separate document, i.e., the contract (...)(see point II of the factual justification).

II. Management of the risk of personal data protection breaches.

Regulation 2016/679 introduced an approach in which risk management forms the foundation of actions related to personal data protection. Risk management is a continuous process that requires the data controller not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. Therefore, it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk, as

also take into account the nature of the given organization and the mechanisms used for processing personal data. The administrator must independently conduct a detailed analysis of the data processing processes and assess the risks, and then apply such measures and procedures that will be adequate to the estimated risk. The consequence of such an approach is the necessity to independently select safeguards based on a threat analysis. It should be emphasized that specific measures and procedures regarding security are not indicated to the administrators.

In this context, it should be noted that the risk analysis conducted by the data administrator should be documented and justified primarily based on the determination of the factual state existing at the time of its execution. It is necessary to take into account, in particular, the characteristics of the ongoing processes, assets, vulnerabilities, threats, and existing safeguards within the ongoing processes of

personal data processing. It is also important not to overlook the scope and nature of the personal data processed during the activities carried out by the data administrator, as the potential negative consequences for the individual in the event of a breach of their personal data protection will depend precisely on the scope and nature of the disclosed data.

The term "assets" is used to indicate everything that constitutes value for the data administrator. Certain assets will have a higher value than others, and from this perspective, they should also be assessed and secured. The interconnections of the existing assets are also very important; for example, the confidentiality of assets (personal data) will depend on the type and manner of processing that data. Determining the value of assets is necessary to assess the consequences of a potential breach of personal data protection. It is obvious that a wide range of personal data or the processing of personal data referred to in Article 9 or Article 10 of Regulation 2016/679 may cause (in the event of a breach of personal data protection) far-reaching negative consequences for the individuals concerned, so they should be assessed as high-value assets, and consequently, the level of their protection should be appropriately high.

Determining existing or applied safeguards is necessary, among other things, to avoid duplication. It is also imperative to verify the effectiveness of these safeguards, as the existence of an untested safeguard may, firstly, eliminate its value, and secondly, may create a false sense of security and may result in overlooking (not detecting) a critical vulnerability, which, if exploited, could lead to very negative consequences, particularly resulting in a breach of personal data protection. A vulnerability is commonly defined as a weakness or gap in security that, if exploited by a given threat, can disrupt operations and may also lead to incidents or breaches of personal data protection. Identifying threats involves determining what threats may arise and from what direction (cause).

One method of conducting a risk analysis is, for example, to define the level of risk as the product of the probability and consequences of a given incident occurring. A risk matrix is typically used, which allows for a visual representation of risk levels, presenting the levels of risk for which the organization defines appropriate actions. It should be emphasized that risk management (conducting a risk analysis and implementing appropriate safeguards based on it) is one of the fundamental elements of the personal data protection system and is a continuous process. Therefore, there should be periodic verification of both the adequacy and effectiveness of the applied safeguards, in accordance with the requirement set out in Article 32(1)(d) of Regulation 2016/679. The data administrator should regularly test, measure, and assess the effectiveness of technical and organizational measures designed to ensure the security of processing.

New risks or threats may materialize or be revealed independently, in a manner completely independent of the administrator, and this is a fact that should also be taken into account both when building the personal data protection system and during its implementation. This, in turn, defines the necessity of conducting regular verification of the entire personal data protection system in terms of both the adequacy and effectiveness of the implemented organizational and technical solutions. It should also be emphasized that assessing the probability of a given event occurring should not be based solely on the frequency of occurrences of events in a given organization, as the fact that a given event has not occurred in the past does not mean that it cannot occur in the future.

In this context, it should be noted that the Administrative Court in Warsaw, in its judgment of August 26, 2020, case file II SA/Wa 2826/19 (upheld by the judgment of the Supreme Administrative Court on February 28, 2024, case file II OSK 3839/21), stated that "(...) technical-organizational activities are the responsibility of the personal data administrator, but they cannot be selected in a completely free and voluntary manner, without taking into account the level of risk and the nature of the protected personal data."

Considering, in particular, the scope of personal data processed by the Administrator in order to properly fulfill the obligations imposed by the aforementioned provisions of Regulation 2016/679, the Administrator was obliged to take actions ensuring an appropriate level of data protection by implementing appropriate technical measures and

organizational actions aimed at optimally securing and configuring the utilized resources, tools, and devices (including computer hardware) through regular testing, measuring, and assessing the effectiveness of technical and organizational measures designed to ensure the security of data processing in the form of security tests concerning the IT infrastructure and applications. The nature and type of these actions should result from a conducted risk analysis, in which vulnerabilities related to the utilized resources should be identified, as well as the threats arising from them, and then appropriate security measures should be determined. As emphasized by the Administrative Court in Warsaw in its judgments of May 13, 2021, case file II SA/Wa 2129/20, and October 5, 2023, case file II SA/Wa 502/23, "The data administrator should therefore conduct a risk analysis and assess what threats they are dealing with."

The work related to transferring the IT system used for processing personal data to another location should be preceded by detailed analyses to determine the impact of this action on the security of the data processed in that system. It is particularly important to verify whether appropriate technical and organizational measures ensuring data confidentiality were used to carry out this operation. The obligations in this regard for the Administrator and the Processor arise directly from Article 32(1) and (2) of Regulation 2016/679.

In the factual state of this case, as indicated in the letter of April 25, 2022, the Administrator did not conduct a risk analysis before transferring the website from the previous hosting service provider to a server in the infrastructure of A., stating that according to § (...) paragraph 1 letter (...) of the contract (...) conducting such an analysis was the obligation of the Processor.

The supervisory authority, assessing the evidential value of the submitted contracts regulating the cooperation between A. and X. (contract (...) and contract (...) – discussed in detail in point II of the factual justification), found that they do not clearly indicate that the Processor received sufficient information from the Administrator necessary for the transfer of the website to a new environment in a manner guaranteeing security for the process of processing personal data. The lack of convincing evidence confirming proper communication between the Administrator and the Processor also pertains to the cooperation between these entities related to the necessity of conducting a risk analysis.

It should therefore be emphasized that the deficit of proper communication manifests itself right at the beginning of the personal data processing process, which was carried out at the request of the Administrator by the Processor. The discussed contracts (and particularly the data processing entrustment agreement) are constructed in a very general manner (cf. point II of the factual justification). The Administrator, in drafting the entrustment agreement, essentially copied the content of some articles of Regulation 2016/679 and did not relate its provisions to specific activities related to the processing of personal data that took place on behalf of the Administrator by the Processor. The supervisory authority does not dispute that the entrustment agreement presented during the administrative proceedings was concluded. However, the evidential value of this document concerning specific facts that, according to the Administrator, occurred is minimal.

In the discussed case, it should be emphasized that risk analysis and risk management are processes requiring the cooperation of all interested parties and, as such, require primarily planning, organizing, directing, and controlling the resources used for processing, executing the processing activities themselves, and examining and detecting potential vulnerabilities and gaps. In particular, it is necessary to analyze the impact of each change on the level of security of the processed data. Consequently, before undertaking any actions, especially those involving, for example, transferring a resource containing personal data from one location to another, the Administrator and the Processor should exercise utmost caution, and before implementing the change itself, they should define the principles of its introduction, especially in the context of ensuring an appropriate level of security for the processed data, and check whether the operation has been completed successfully not only in terms of the operational efficiency of the application or system but also in terms of meeting the legal requirements, including the provisions of Regulation 2016/679 imposing obligations regarding ensuring an appropriate level of data security. Considering the above, it should be noted that the Administrator was obliged to verify whether personal data is adequately secured against unauthorized access.

The thesis of A. contained in the letter of September 27, 2021, stating that the fact that the website (...) is a database is irrelevant to these proceedings, and that the fact that it contained personal data is a secondary issue (cf. point VIII of the factual justification), does not merit consideration. It is precisely the fact that the said website contained a database of personal data that is crucial from the perspective of personal data protection, as this fact determines the necessity of implementing specific (adequate) technical measures aimed at ensuring the security of personal data processing. The supervisory authority does not indicate to the administrators what technical conditions they should meet to prevent breaches of personal data protection. It is the Administrator, being aware that they are processing personal data, knowing their nature and scope, who must diligently...

conducts a risk analysis determines what adequate organizational and technical measures should be implemented by him. Moreover, he should be able to demonstrate – before the supervisory authority – that such measures have indeed been implemented. As indicated by the WSA in Warsaw in its judgment of October 5, 2023, case file II SA/Wa 502/23, "the supervisory authority is not obliged to indicate to the Administrator the technical and organizational solutions that he should implement to ensure that the processing of personal data is carried out in accordance with the law. It is the Administrator's task to introduce these measures and then, if necessary, to demonstrate that he complies with the principles of personal data processing specified in Regulation 2016/679, in accordance with the principle of accountability (Article 5(2) of the aforementioned regulation)." Furthermore, the NSA in its judgment of February 9, 2023, case file III OSK 3945/21, stated that "Under GDPR, the legislator has moved away from a static definition of the technical and organizational measures required from the administrator in favor of a dynamic assessment of the adopted security measures. This means that it is the responsibility of the administrator and the data processor to determine appropriate (adequate) security measures, while maintaining the competence of the supervisory authority to verify the adopted level of security."

Entrusting the processing of personal data to a data processor does not relieve the Administrator of the obligations arising from Article 32(1) and (2) of Regulation 2016/679. Therefore – contrary to the position of A. indicated in the letter of September 27, 2021 – a key issue is the fact that the transferred website contained a database of personal data of the Company's clients.

According to Article 4(7) of Regulation 2016/679, "administrator" means a natural or legal person, a public authority, an agency, or any other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the administrator may also be designated by Union law or the law of a Member State, or specific criteria for its designation may be laid down.

On the other hand, Article 4(8) of Regulation 2016/679 states that "data processor" means a natural or legal person, a public authority, an agency, or any other body which processes personal data on behalf of the administrator. Highlighting the relationship between the administrator and the data processor, it should be emphasized that the obligation to conduct a thorough risk analysis also arises from the aforementioned legal provisions contained in Articles 24 and 25 of Regulation 2016/679 – which only refer to the administrator. Therefore, using the services of a data processor does not relieve the administrator of the obligations to select adequate measures ensuring security in the process of personal data processing and cannot serve as an argument for transferring the responsibility for the selection and implementation of the measures mentioned above to the data processor.

It should be noted that for a proper risk analysis, it is essential to have a full spectrum of information. Even if one were to assume that from this general provision of the entrustment agreement it follows that the obligation to conduct a risk analysis rested solely on the data processor (which in itself contradicts Article 32(1) of Regulation 2016/679), the data processor, in order to conduct such a risk analysis, should have knowledge regarding at least the fact that the transferred website contains personal data of a specific scope, processed for a specific purpose.

The Administrator, during the administrative proceedings, did not substantiate – in accordance with the

principle of accountability – that he provided the Data Processor with information that the transferred website contained a database of personal data with specific characteristics.

Confirmation of the lack of effective communication is provided by the report on the incident analysis submitted during the proceedings for A., which indicated that the transfer of the website to the new environment occurred without verifying the vulnerabilities of the transferred website (cf. point I of the factual justification). It should be emphasized that the identification of these vulnerabilities should have occurred as part of the conducted risk analysis, and A. did not present convincing evidence that he provided the Data Processor with all necessary information for its execution, while also not conducting such an analysis himself.

According to the risk-based approach established in the provisions of Regulation 2016/679, entrusting processing to a Data Processor does not exclude the Administrator's responsibility for ensuring the security of processing. It should be noted that Recital 74 of Regulation 2016/679 advocates imposing obligations on the administrator and establishing legal liability for the processing of personal data by himself or on his behalf. In particular, the administrator should be obliged to implement appropriate and effective measures and should be able to demonstrate that the processing activities are in compliance with this regulation and that they are effective. These measures should take into account the nature, scope, context, and purposes of the processing as well as the risk of infringement of the rights and freedoms of natural persons. In the literature on the subject, it is pointed out that "the provisions impose obligations on the administrator regarding compliance with the principles and burden him with liability for their violation. The commented regulation shows a tendency to provide administrators with greater freedom regarding the security measures applied, while simultaneously increasing liability for violations of data protection regulations."

the processor; b) ensures that persons authorized to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality; c) takes all measures required pursuant to Article 32 of Regulation (EU) 2016/679; d) respects the conditions referred to in paragraphs 2 and 4 of Article 28 of Regulation (EU) 2016/679 for engaging another processor; e) assists the controller by appropriate technical and organizational measures, insofar as this is possible, for the fulfillment of the controller's obligation to respond to requests for exercising the data subject's rights laid down in Chapter III of Regulation (EU) 2016/679; f) assists the controller in ensuring compliance with the obligations pursuant to Articles 32 to 36 of Regulation (EU) 2016/679, taking into account the nature of processing and the information available to the processor; g) at the choice of the controller, deletes or returns all personal data to the controller after the end of the provision of services relating to processing, and deletes existing copies unless Union or Member State law requires storage of the personal data; h) makes available to the controller all information necessary to demonstrate compliance with the obligations laid down in Article 28 of Regulation (EU) 2016/679 and allows for and contributes to audits, including inspections, conducted by the controller or another auditor mandated by the controller.

In light of the above, it is essential to emphasize that the administrator bears the primary responsibility for ensuring that the processing of personal data complies with the provisions of Regulation (EU) 2016/679. The administrator must ensure that any processing carried out by the processor is done in accordance with the law and that the necessary safeguards are in place to protect the rights of data subjects.

IV. Conclusion

In conclusion, the analysis of the presented documents and the obligations arising from Regulation (EU) 2016/679 indicates that the Administrator has not fulfilled its responsibilities regarding the protection of personal data. The lack of a risk assessment prior to the data breach and the failure to monitor the adequacy and effectiveness of the security measures in place demonstrate a clear violation of the principles of accountability and compliance with data protection regulations. The Administrator must take immediate corrective actions to ensure compliance and protect the rights of data subjects.

****Processor,**** in such a case, before starting the processing, the processor informs the controller of

this legal obligation, unless the law prohibits providing such information due to an important public interest;

- b) ensures that persons authorized to process personal data are committed to confidentiality or are subject to an appropriate statutory obligation of confidentiality;
- c) takes all measures required under Article 32;
- d) complies with the conditions for using the services of another processor referred to in paragraphs 2 and 4;
- e) taking into account the nature of the processing, assists the controller, where possible, by means of appropriate technical and organizational measures to fulfill the obligation to respond to requests from the data subject regarding the exercise of their rights as defined in Chapter III;
- f) considering the nature of the processing and the information available to it, assists the controller in fulfilling the obligations specified in Articles 32–36;
- g) after the completion of the services related to processing, depending on the controller's decision, deletes or returns all personal data to the controller and deletes all existing copies thereof, unless Union law or the law of a Member State requires the retention of personal data;
- h) provides the controller with all information necessary to demonstrate compliance with the obligations set out in this article and allows the controller or an auditor authorized by the controller to conduct audits, including inspections, and contributes to them. In connection with the obligation specified in the first paragraph letter h), the processor shall promptly inform the controller if it believes that an instruction given to it constitutes a violation of this regulation or other Union or Member State data protection laws.

The need to verify the processor is highlighted in the EDPB Guidelines 7/2020 concerning the concepts of the controller and the processor contained in the GDPR. It is indicated that “(...) the guarantees by the processor are those that the processor can demonstrate satisfactorily to the controller, as these are the only guarantees that the controller can effectively take into account when assessing the fulfillment of its obligations. This will often require the exchange of appropriate documentation [e.g., privacy policies, terms of service, records of processing activities, document management policies, information security policies, reports from external data protection audits, recognized international certifications such as ISO 27000 standards] (...) The controller's assessment of whether the guarantees are sufficient is a form of risk assessment that largely depends on the type of processing entrusted to the processor and must be conducted individually for each case, taking into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. Therefore, the EDPB cannot provide an exhaustive list of documents or actions that the processor must demonstrate or prove in a given scenario, as this largely depends on the specific circumstances of the processing (...).”

During the administrative proceedings, A. indicated how he verified whether the Processor provides a guarantee of implementing appropriate technical and organizational measures to meet the security requirements of the personal data processing process. A detailed description of this verification is included in point III of the factual justification. In this regard, the supervisory authority accepted the explanations provided by the Controller and did not find grounds to question that A. – before entering into cooperation with the Processor – verified X. in the area of providing sufficient guarantees for the implementation of appropriate technical and organizational measures to ensure that the processing of personal data meets the requirements of Regulation 2016/679 and protects the rights of the data subjects. However, it should be emphasized that – similarly to the necessity of conducting a risk analysis – the obligation of this verification is a continuous obligation. It should be noted that the consequences of neglecting the obligation of continuous verification by the controller of the guarantees referred to in Article 28(1) of Regulation 2016/679 may directly affect the natural persons whose personal data have been entrusted to the processor. The need for continuity in verifying the processor is indicated in the EDPB Guidelines 07/2020, which state that “(...)

99: The obligation to use only the services of processors ‘providing sufficient guarantees’ contained in Article 28(1) of the GDPR is a continuous obligation. It does not end at the moment of concluding a contract or other legal act by the controller and the processor. The controller should rather verify the

guarantees of the processor at appropriate intervals, including, where appropriate, through audits and inspections (...)."

As already indicated above, the Controller conducted a verification of the Processor before entering into the data processing agreement, and a circumstance taken into account in this process by A. was the fact of prior cooperation with X., during which the Company did not find any reservations regarding the quality of the work performed, nor any other issues related to the processing of personal data or matters concerning information security or managed IT systems. Given that the verification of the processor must be a continuous process, it should be noted that long-term cooperation between the parties not supported by periodic, systematic audits or inspections does not guarantee that the processor...

the proper execution of tasks required by law and arising from the concluded delegation agreement.

In this case, the Administrator's verification of the way the Processor implemented changes related to the transfer of the website to a new environment would significantly reduce the risk of unauthorized access to personal data processed on the website (...). The consequence of the above omission was the lack of actions by A. to ensure the security of personal data of its clients, which it was obliged to do in accordance with the aforementioned provisions of Regulation 2016/679, as the administrator of that data. It should also be emphasized that the fact of using the services of the processor does not exempt the Administrator from these obligations. The responsibilities in this regard primarily rest with the data administrator.

Analyzing the actions (or rather the lack of actions) of the Administrator in this regard, one can conclude that it merely reported to the Processor the need to transfer the website to a new environment, without taking any actions to verify whether the security of personal data processing of clients was ensured during the process of making changes in the system.

Based on Article 28(3)(h) of Regulation 2016/679, the administrator has the right to conduct audits, including inspections, at the processor. The purpose of these actions by the administrator should be the ongoing verification of whether the processor fulfills all obligations specified in Article 28(3) of Regulation 2016/679. In the context of this case, considering the nature of the task commissioned by A. to X. involving the transfer of the website (...) to a new environment, it was particularly important to verify whether the Processor was taking all measures required under Article 32 of Regulation 2016/679. The President of the UODO asked the Administrator to indicate whether it exercised the right of control referred to in Article 28(3)(h) of Regulation 2016/679. In response to the precisely formulated question from the supervisory authority, A. provided an evasive answer that had no real connection to the inquiry of the supervisory authority (see point IV of the factual justification).

Considering the above, it must be stated that A. did not exercise the right to conduct audits, including inspections, at the processor to check whether X. properly fulfills its obligations arising from Regulation 2016/679. The explanations provided by the Administrator indicating that "(...) regular testing, measuring, and evaluating the effectiveness of the organizational and technical measures taken to ensure the security of personal data processing in the IT area were partially entrusted to company X. as part of the overall cooperation of the Administrator. These activities included reviews of reports from the tools used, analyses and decisions related to additional security, or testing the IT infrastructure for the presence of TOP10 OWASP vulnerabilities (report submitted with the letter dated June 3, 2020)" are irrelevant to the issue of A.'s control over X.

It should be emphasized how crucial the possibility of controlling the processor is as an element of the verification process. Article 28(3)(h) of Regulation 2016/679 provides the administrator with tools to ensure that the data processing entrusted will comply with the standards set out in Regulation 2016/679, and the submission of evidence confirming the performance of such control actions – in accordance with the principle of accountability – can demonstrate that the Administrator took actions aimed at verifying the processor, ensuring that it implemented appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679 and protects the rights of the data subjects. It should be emphasized that the discussed right of the administrator should

be treated as one of the more significant security measures that it should apply to properly fulfill its obligations arising from Article 32(1) of Regulation 2016/679. The Administrator should, during its use of the services of the processor, possess knowledge of whether and how the entity to which it entrusted the processing of personal data meets the requirements specified in Regulation 2016/679. Notably, the agreement submitted by the Administrator (...) contained provisions allowing for such controls and precisely defined the rules for their conduct (see point II of the factual justification), and despite this, A. did not provide evidence that such control actions were undertaken by it.

Moreover, as demonstrated above, the application of the aforementioned measures is linked to the obligation of the data administrator arising from Article 28(1) of Regulation 2016/679, which in turn means that its execution must also confirm whether the processor continues to guarantee the implementation of appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679 and protects the rights of the data subjects. The failure to conduct audits, including inspections, at the Processor consequently constitutes a violation by the Administrator not only of Article 28(1) of Regulation 2016/679 but also of Article 25(1) of Regulation 2016/679, which obliges it to implement appropriate technical and organizational measures, both when determining the methods of processing and during the processing itself. The continuity inherent in this obligation may therefore manifest itself in practice, among other things, in the necessity to ensure... regular monitoring of the applied safeguards and maintaining constant supervision over the data processor through, for example, audits and inspections referred to in Article 28(3)(h) of Regulation 2016/679, which were lacking in the circumstances of this case. Contrary to the guidelines of EROD 7/2020, the Administrator, during the ongoing proceedings, attempted to justify the fact that entering into a data processing agreement with an external entity specializing in IT security absolves him from responsibility for implementing the organizational and technical measures referred to in Article 32 of Regulation 2016/679, and that this responsibility lies solely with the Data Processor.

According to the guidelines of EROD 7/2020, it should be noted that:

135: Moving on to specific obligations, the data processor has the obligation, firstly, to assist the administrator in fulfilling the obligation to adopt appropriate technical and organizational measures to ensure the security of processing. Although this may somewhat overlap with the requirement that the data processor itself adopts appropriate security measures, in cases where the processing operations carried out by the data processor fall within the scope of the GDPR, they remain two distinct obligations, as one pertains to the data processor's own measures, while the other pertains to the data controller. 138: The obligation to assist does not involve the transfer of responsibility, as these obligations are imposed on the data controller. For example, although a data protection impact assessment may, in practice, be carried out by the data processor, the controller remains responsible for the obligation to conduct the assessment, and the data processor is obliged to assist the controller "if necessary and upon request." Consequently, it is the controller who must take the initiative to conduct the data protection impact assessment, not the data processor.

From Article 32 of Regulation 2016/679, interpreted in light of the above-cited guidelines, it follows that the obligations to implement organizational and technical measures are imposed on both data processors and data controllers. Therefore, the fact that a contract was concluded and certain data processing activities were entrusted to the data processor does not relieve the controller of the obligation to implement appropriate technical and organizational measures referred to in Article 32 of Regulation 2016/679, nor does it exempt the data controller from the obligation to maintain constant supervision over the data processor in this regard.

As a result, in the opinion of the President of UODO, the technical and organizational measures applied by the Administrator corresponded only to a very limited extent to the requirements specified in Article 32 of Regulation 2016/679, given that the Administrator did not enforce the provisions of their agreements with X. and did not verify the Data Processor regarding the actions it undertook to transfer the old website. At no stage of the work conducted on the IT systems did the Administrator supervise whether the implementation was actually proceeding in accordance with generally applicable standards and the data processing agreement. During the ongoing proceedings, the Administrator did

not demonstrate that by commissioning the Data Processor to transfer the historical website (...) to a new environment, he informed the Data Processor that the personal data of his clients were being processed in the website's environment. The Data Processor, in its explanations dated July 15, 2021, indicated that during the period of cooperation, it did not receive any information from the Administrator about the functionality of the website, and in particular, that the task of transferring the website involved the processing of personal data of clients A., that the aforementioned data were not transmitted to the local enterprise management system but were collected directly in the website's database. Consequently, according to the submitted explanations, the Data Processor, until the occurrence of a personal data breach, was unaware of the contents of the database of the transferred website and thus did not take any actions to secure them, e.g., by encrypting them. The actions taken by X. focused solely on securing the website, among other things, by placing it on an updated server, connecting the server to the public network, which enabled incoming connections on the ports indicated by the software manufacturer L., and activating traffic filtering to the server, as well as launching an additional firewall for the website.

The Administrator, when commissioning the Data Processor to perform activities related to data processing, should define them in a manner that leaves no doubt as to what the commissioned activities entail. During the ongoing proceedings, the Administrator indicated that the Data Processor, as a professional entity, must have known that the transfer operation also involved the transfer of customer data. However, the Administrator did not provide evidence confirming that he had communicated information regarding the processing of personal data of his clients in the website's database. In his explanations, the Administrator referred to the fact that the support from the Data Processor was very broad and that the Data Processor was responsible for the IT area, and the scope of personal data was specified in the annex to the data processing agreement, indicating the data contained in the IT systems, which did not include the website (...). The Administrator, in his explanations, indicated that the scope of data processed via the website (...) was not broader than the extent of providing necessary information regarding the processing of personal data, as well as to assist the administrator in fulfilling their obligations under the applicable regulations.

1. Scope of Data Processed in the Specified IT Systems. In this regard, it should be emphasized that it is unacceptable for the Administrator to leave these matters to the discretion of the Data Processor solely because a data processing agreement was signed with them. This is especially true in situations where the transfer of the website was one of many services provided by the Data Processor to the Administrator under the agreement regarding (...).

2. It should also be noted that within the framework of cooperation between A. and X., the Data Processor communicated its doubts to the Administrator regarding the level of security of the IT infrastructure. As indicated by the explanations provided by the Data Processor, X. informed the Administrator that the website was based on outdated software and that it should have a substantive guardian to ensure oversight of its operation. Such communications should lead to increased vigilance on the part of the Administrator. A. should at least have reviewed the procedures defining the scope of responsibility of the Data Processor, i.e., should have established with X. who is responsible for securing the website (including software updates) on which the personal data database is located.

3. Meanwhile, in the case under discussion, the data processing agreement was constructed in such a way that even the Data Processor, within the framework of this administrative proceeding, presented the position that the discussed data processing agreement did not address the issue of entrusting the processing of personal data in connection with the operation of the website (...) (cf. point VI of the factual justification). Even if we assume that X.'s explanations in this area were provided by this entity to avoid liability for violating the provisions of Regulation 2016/679, this does not change the fact that the discussed data processing agreement was constructed in a manner that raises doubts regarding the scope of the entrusted personal data and the scope of the activities that the Data Processor committed to perform in connection with the processing of this data.

4. In this case, the responsibility lies primarily with the Administrator, as it was A. who made the decision to choose a specific economic entity. It is the Administrator who should select a Data

Processor that provides sufficient guarantees for the implementation of appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679 and protects the rights of the data subjects. The Administrator should exercise due diligence when entering into contracts (including the data processing agreement) so that this agreement precisely defines the subject and duration of the processing, the nature and purpose of the processing, the type of personal data, and the categories of data subjects, as well as the obligations and rights of the parties.

5. However, it should not escape attention that due to the lack of instructions from the Administrator regarding how the server should be configured in connection with the transfer of the website, the Data Processor, to eliminate any doubts, should verify whether, during the execution of this task, it would be processing personal data and determine what functions the website serves, whether and what data is processed through it, and adjust the security measures accordingly. In the absence of sufficient information, the Data Processor should conduct a risk analysis on its own and then decide whether to undertake the execution of the given order.

6. At the same time, it should be pointed out that considering the period of cooperation between X. and the Administrator (including the fact that X. and A. entered into a data processing agreement), the knowledge of its IT infrastructure and the nature of the activities conducted by it, the Data Processor, for broadly understood security and to fulfill the duty of care that rests on it as a qualified entity, could have inquired about the content of the database and the location of the data processed on the website.

7. According to the judgment of the Provincial Administrative Court in Warsaw of October 5, 2021, case file II SA/Wa 528/21, "(...) the deputy [representative] of the administrator is a separate legal entity, acting on behalf of the represented, based on the authorization granted in the data processing agreement concluded with the administrator. If the processing activities are performed by the Data Processor and not the administrator, then, in principle, the provisions defining the obligations related to processing should be applied to this deputy. However, Regulation No. 2016/679 distributes these obligations between the administrator and the Data Processor, which means that the administrator, by entrusting the processing of data to another entity, is not completely relieved of responsibility for failing to meet the legal requirements regarding processing. The provisions of the regulation direct some obligations to the data administrator (Article 5(2)), while others are addressed simultaneously to both the administrator and the Data Processor (Article 32(1) and (2)).

8. Furthermore, the Data Processor has separate obligations in this regard (Article 28 of the regulation). Although these obligations of the Data Processor should be included in the data processing agreement concluded between the parties, the mandatory inclusion of them in the agreement does not strip them of their public law character, nor does it make them exclusively contractual obligations, which is of fundamental importance for determining liability for their violation and is confirmed by Article 83(4)(a) of the regulation. It should be emphasized that the Data Processor is obliged to cooperate with the administrator, and even to...

of the application and WebAPI system (...), concerning vulnerabilities that could lead to data breaches.

V. Obligation to conduct regular testing, measuring, and evaluating the effectiveness of security measures for the processing of personal data.

Another aspect of personal data protection that is significant from the perspective of the decision contained in this document is the necessity of conducting regular testing, measuring, and evaluating the effectiveness of security measures for the processing of personal data (Article 32(1)(d) of Regulation 2016/679). In this regard, the Administrator provided explanations indicating that regular testing, measuring, and evaluating the effectiveness of security measures related to the operation of the previous website (...), was entrusted to the Data Processor.

These actions were to be carried out by X. as part of the basic tasks performed in connection with the service provided to A. (see point V of the factual justification). As evidenced by the gathered evidence, the Administrator did not conduct regular testing, measuring, and evaluating the effectiveness of the technical and organizational measures intended to ensure the security of processing on its own. The Administrator indicated that the record of activities attached to the case file shows that tests on the

website were conducted before the incident occurred, which in its opinion confirms that actions related to data processing and information security were monitored. It should be noted that the presented evidence regarding monitoring and testing the website's vulnerabilities and the tests conducted were performed solely by the Data Processor and concerned the website itself and its functionality, not the threats arising from processing personal data of clients, of which the Data Processor was unaware. Additionally, despite the evidence presented by the Administrator confirming that the Data Processor conducted regular testing, measuring, and evaluating the effectiveness of security measures, the vulnerability that led to the breach of personal data protection of clients was not detected.

It should also be emphasized that the fact that the Data Processor conducted regular testing, measuring, and evaluating the effectiveness of security measures for the processing of personal data does not exempt the Administrator from the obligation to carry out such activities. A. should have at least verified whether X.'s actions in this regard were conducted properly. Regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of processing is a fundamental obligation of every administrator and data processor arising from Article 32(1)(d) of Regulation 2016/679.

The Administrator is therefore obliged to verify both the selection and the level of effectiveness of the technical measures used at every stage of processing. The comprehensiveness of this verification should be assessed in light of its adequacy to risks and proportionality in relation to the state of technical knowledge, costs of implementation, and the nature, scope, context, and purposes of processing. Testing, measuring, and evaluating, in order to fulfill the requirement arising from Article 32(1)(d) of Regulation 2016/679, must be conducted regularly, consciously planned, organized, and documented (in connection with the accountability principle - Article 5(2) of Regulation 2016/679) within specified time intervals, regardless of changes in the organization and course of data processing processes, caused, for example, by entrusting the processing of personal data to a data processor. A. did not undertake such actions (and was entitled to do so under Article 28(3)(h) of Regulation 2016/679), which constitutes a violation of this provision of Regulation 2016/679.

In a similar factual situation, the Provincial Administrative Court in Warsaw, in its judgment of October 21, 2021, case file II SA/Wa 272/21, stated that "(...) the President of the UODO was also correct in pointing out in the justification of the contested decision that the lack of regulations in the procedures adopted by the Company ensuring regular testing, measuring, and evaluating the effectiveness of the technical and organizational measures applied to ensure the security of data processing contributed to the occurrence of a personal data breach. The authority also rightly points out that it was demonstrated in the proceedings that the Company did not conduct tests aimed at verifying the security of the application (...) and the WebAPI system (...), concerning vulnerabilities."

the obligations of the Administrator and the Processor, as referred to in Articles 8, 11, 25–39, and 42 and 43, are subject to an administrative fine of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total worldwide annual turnover from the previous financial year, whichever amount is higher.

In accordance with Article 83(5)(a) of Regulation 2016/679, the infringements of the provisions concerning the obligations of the Administrator and the Processor, as mentioned above, shall be subject to an administrative fine.

The President of the Personal Data Protection Office, utilizing the powers conferred upon him by the aforementioned provision of Regulation 2016/679, determined that in the case at hand, there were grounds justifying the imposition of an administrative fine on A. and X.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the Administrator and the Processor, as referred to in Articles 8, 11, 25–39, and 42 and 43, are subject to an administrative fine of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total worldwide annual turnover from the previous financial year, with the higher amount applicable.

The findings of the factual state indicate that the measures applied by the Administrator and the

Processor to ensure the security of personal data were not adequate to the state of technical knowledge, the costs of implementation, and the nature, scope, context, and purposes of processing, which consequently did not ensure effective realization of data protection principles. Consequently, in the opinion of the President of the Personal Data Protection Office, both A. and X. failed to implement appropriate technical and organizational measures to ensure the security of personal data contained in the transferred website, which constitutes a violation of Article 32(1) and (2) of Regulation 2016/679.

It should also be noted that the obligations regarding the implementation of appropriate technical and organizational measures to ensure that processing is carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing to meet the requirements of Regulation 2016/679 were imposed on the Administrator (and only on the Administrator) by the provisions of Article 24(1) and Article 25(1) of Regulation 2016/679. Due to the lack of application by A. of adequate security measures, as mentioned above, it should be concluded that the Administrator also violated these provisions of Regulation 2016/679. The consequence of their violation is the necessity to state that the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679 was also violated by A., and consequently, the principle of accountability referred to in Article 5(2) of Regulation 2016/679.

It should be emphasized that the proper and effective protection of data has been elevated in Regulation 2016/679 to the status of a general principle, which indicates that the issue of ensuring data confidentiality should be treated in a particular and priority manner by the Administrator. Meanwhile, as demonstrated in the justification of this decision, both the Administrator and the Processor failed to implement appropriate technical and organizational measures to ensure the security of personal data processing, which led to a breach of their confidentiality in connection with the occurrence of a personal data breach.

When applying the provisions of Regulation 2016/679, it should be borne in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In case of any doubts, for example, regarding the fulfillment of obligations by Administrators – not only in situations where there has been a personal data breach, but also when developing technical and organizational security measures to prevent them – these values should be taken into account first and foremost.

In order to monitor and enforce compliance with the provisions of Regulation 2016/679, the President of the Personal Data Protection Office has been equipped with instruments that serve to ensure that the Administrator and/or the Processor fulfills the obligations imposed on them by this regulation. At the same time, both A. and X. must bear responsibility for the identified violations of the provisions of Regulation 2016/679.

VI. Justification for the imposition and determination of the amount of the administrative monetary penalty.

Based on Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of this regulation, an administrative monetary penalty under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the findings of the factual state, the President of the Personal Data Protection Office, exercising the powers conferred upon him by the aforementioned provision of Regulation 2016/679, determined that in the case at hand, there were grounds justifying the imposition of an administrative monetary penalty on A. and X.

****Basic Principles of Processing, Including Conditions of Consent****

The principles and conditions referred to in Articles 5, 6, 7, and 9 are subject, in accordance with paragraph 2, to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable. Article 83 paragraph 3 of Regulation 2016/679 states that if the Administrator or Processor

intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative fine shall not exceed the amount of the fine for the most serious violation.

In this case, the administrative fine imposed on A. was for violating Article 25 paragraph 1, Article 28 paragraph 1, Article 32 paragraphs 1 and 2 of Regulation 2016/679 based on the aforementioned Article 83 paragraph 4 letter a) of Regulation 2016/679, while for the violation of Article 5 paragraph 1 letter f) and Article 5 paragraph 2 of Regulation 2016/679 – based on Article 83 paragraph 5 letter a) of that regulation. At the same time, the fine amounting to the equivalent of 350,000 EUR imposed on A. for the violation of all the above provisions – in accordance with Article 83 paragraph 3 of Regulation 2016/679 – does not exceed the amount of the fine for the most serious violation identified in this case, namely the violation of Article 5 paragraph 1 letter f) of Regulation 2016/679, which, according to Article 83 paragraph 5 letter a) of Regulation 2016/679, is subject to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year.

On the other hand, the administrative fine imposed on the Processor was for violating Articles 32 paragraphs 1 and 2 and Articles 32 paragraphs 1 and 2 in connection with Articles 28 paragraphs 3 letters c) and f) of Regulation 2016/679 based on Article 83 paragraph 4 letter a) of Regulation 2016/679, which, according to this provision of law, is subject to an administrative fine of up to 10,000,000 EUR, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year.

****VI. a) Justification for the Imposition and Determination of the Amount of the Administrative Fine on A. ****

In deciding to impose an administrative fine on A., the President of UODO – in accordance with the provisions of Article 83 paragraph 2 letters a) - k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which aggravate the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83 paragraph 2 letter a) of Regulation 2016/679). In this case, violations of the provisions: Article 24 paragraph 1, Article 25 paragraph 1, Article 28 paragraphs 1 and 3, Article 32 paragraphs 1 and 2, Article 5 paragraph 1 letter f) and Article 5 paragraph 2 of Regulation 2016/679 were identified. The violation of the aforementioned provisions was related to an incident involving the disclosure of personal data of A.'s clients on a wide scale. When determining the fine, it was significant that the violation of the provisions of Regulation 2016/679, which impose obligations on the Administrator regarding the implementation of appropriate technical and organizational measures to ensure the security of the processed personal data, affected the confidentiality of data of over 21 thousand clients of the Administrator. Therefore, it has considerable weight and serious character, as it may lead to material or non-material damage to the individuals whose data has been violated, and the probability of such damage occurring is high.

Furthermore, the risk arising from the wide scope of data covered by the violation, the large number of data subjects, as well as the large scale and professional nature of the data processing must be taken into account. It should be emphasized that there remains a high risk of unlawful use of the personal data of the individuals whose data has been violated, as the purpose for which unauthorized persons obtained the file containing the Administrator's client database is unknown. Therefore, the individuals concerned may still suffer material damage, and the mere violation of data confidentiality also constitutes non-material damage (harm). A data subject may at least feel fear of losing control over their personal data, identity theft, or identity fraud, or finally, financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, fear, and thus loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, regarding Natsionalna

agentsia za prihodite (C-340/21) emphasized that "Article 82 paragraph 1 of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a data subject experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

The President of UODO also considers the long duration of the violation of the provisions of Regulation 2016/679 by A. as an aggravating circumstance. In the case of the violation of Article 28 paragraph 1 of Regulation 2016/679, it should be assumed that the violation lasted from the date of conclusion of the data processing entrustment agreement (July 31, 2019) until the date of termination of the services provided by X. for A. (September 30, 2020). In the case of the violation...

of the remaining provisions of Regulation 2016/679, it should be noted that it lasted from the date of the commencement of cooperation between A. and X. (July 31, 2019) until the day of the introduction of technical and organizational measures aimed at ensuring security in the processing of personal data, the implementation of which the Administrator declared only after the occurrence of a personal data breach in the letter dated June 3, 2020.

2. The unintentional nature of the breach (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Data Protection Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 (hereinafter referred to as WP253 Guidelines), confirmed by the Guidelines 04/2022 on the calculation of administrative fines based on the GDPR (hereinafter referred to as Guidelines 04/2022)[2], intent "includes both knowledge and purposeful action, in relation to the characteristics of the prohibited act." The Administrator was aware that in the case of allowing the processing of personal data in IT systems, he should process personal data in such a way as to ensure appropriate security, and thus in such a way as to ensure compliance with the principle of "integrity and confidentiality" expressed in Article 5(1)(f) of Regulation 2016/679. It should be emphasized that the significant impact on the occurrence of the breach in question was the gross negligence of A. and the disregard for the obligations of the data controller by the Company. Despite being aware of the threat to security in the processing of personal data, the Administrator did not implement adequate measures to guarantee that security, and during the administrative proceedings, he attempted to shift the responsibility for the personal data breach onto the Processor. The collected evidence clearly indicates that A. was aware that – as the data controller – he should implement appropriate technical and organizational measures to ensure that the processing was carried out in accordance with Regulation 2016/679, as evidenced by the conclusion of a data processing agreement, which – by the way – contains provisions directly copied from Article 28(3) of Regulation 2016/679. Despite having this knowledge, the Administrator did not even conduct a risk analysis for the process related to the transfer of the website to a new environment and entrusted the entire process to X., against whom – it should be emphasized again – he did not apply control measures, the possibility of which arises not only from Article 28(3)(h) of Regulation 2016/679 but even from the Agreement (...) (§ (...) (1) (...)) – see point II of the factual justification. Thus, A. unintentionally violated the provisions on the protection of personal data - Article 5(1)(f) of Regulation 2016/679 in conjunction with Articles 24(1), 25(1), 32(1) and (2), and Article 28(1) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679.

3. Any relevant previous violations by the controller or processor (Article 83(2)(e) of Regulation 2016/679). When making a decision on the imposition and amount of an administrative fine, the supervisory authority is obliged to take into account any previous violations of Regulation 2016/679. The EDPB in Guidelines 04/2022 explicitly states: "The existence of previous violations may be considered an aggravating factor when calculating the amount of the fine. The weight attributed to this factor should be determined taking into account the nature and frequency of previous violations. The absence of previous violations cannot, however, be considered a mitigating circumstance, as compliance with the provisions of [Regulation 2016/679] is the norm."

And although, as indicated in the aforementioned guidelines, "greater significance should be attributed to violations concerning the same subject matter, as they are closer to the violation that is the subject of the current proceedings, especially when the controller or processor has previously committed the

same violation (repeated violations)" (point 88 of the guidelines), all previous violations may constitute information about the overall approach of the controller or processor to compliance with the provisions of Regulation 2016/679. The supervisory authority, having identified in other issued administrative decisions a violation by the Administrator of the provisions on the protection of personal data, has already exercised its remedial and admonitory powers against A. The President of UODO issued the following decisions directed to the Administrator: - decision of July 9, 2021 (...), a warning for violating Article 6(1) of Regulation 2016/679, - decision of September 14, 2023 (...), a warning for violating Articles 12(3) and (4) in conjunction with Article 21(2) of Regulation 2016/679 and an order to cease processing personal data. The aforementioned previous violations, identified by the authority as a result of administrative proceedings initiated by individuals filing complaints about irregularities in the processing of their personal data by A., indicate the existence of problems within the structures of the Administrator in fulfilling the obligations arising from the provisions of Regulation 2016/679. The Administrator was not able in the aforementioned individual cases to demonstrate to the supervisory authority the legality of the processing and the proper realization of the right of the individual to object to the processing of their personal data – which resulted in the application of appropriate remedial measures against A. However, it should be noted that the identified problems were not of a systemic or recurring nature.

but concerned individual situations. The fact that the violations identified in the aforementioned proceedings were substantively different from those examined in the present case is also significant for the assessment of the relevant criterion. Thus, the President of the UODO took the position that the previous conduct of the Administrator, indicating existing difficulties in complying with data protection regulations—if interpreted against the Administrator—justifies the current imposition of an administrative monetary penalty; however, it does not significantly affect the increase in its amount.

4. Categories of personal data to which the violation pertained (Article 83(2)(g) of Regulation 2016/679).

The personal data to which the violation of the provisions of Regulation 2016/679 pertained do not belong to the special categories of personal data referred to in Article 9 of Regulation 2016/679; however, their scope, i.e., name and surname, residential or stay address, PESEL identification number, email address, phone number, and encrypted password, is associated with a high risk of infringement of the rights or freedoms of the individuals affected by the violation. It should be emphasized that the fact that the violation involved the protection of personal data such as the PESEL identification number along with the name and surname, which unequivocally identify an individual, can realistically and negatively impact the protection of the rights or freedoms of that person. It should be noted that the PESEL identification number, which is an eleven-digit numerical symbol that unequivocally identifies an individual, containing, among other things, the date of birth and gender designation, and thus closely linked to the private sphere of the individual, is also subject to exceptional protection under Article 87 of Regulation 2016/679 as a national identification number, and requires such special protection.

In this context, it is worth recalling Guidelines 04/2022, which state: "Regarding the requirement to consider the categories of personal data to which the violation pertained (Article 83(2)(g) of Regulation 2016/679), the Regulation clearly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of Regulation 2016/679, as well as to data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the individual to whom the data pertains (e.g., location data, data concerning private communications, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are involved in the violation or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The quantity of data concerning each individual whose data is involved is also significant, as the scale of the violation of the right to privacy and data protection increases with the amount of data concerning each individual."

This view was also shared by the aforementioned Court in its judgment of June 21, 2023, in case file II SA/Wa 150/23, where the WSA in Warsaw stated: "In summary, the Court holds that the disclosure of the PESEL number indicates a high risk of infringement of the rights or freedoms of individuals."

In determining the amount of the administrative monetary penalty, the President of the UODO considered as a mitigating circumstance, which influenced the reduction of the imposed penalty, the good cooperation of the Administrator with the supervisory authority undertaken and conducted to eliminate the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). It should be noted that beyond properly fulfilling the procedural obligations imposed on the Administrator during the administrative proceedings that concluded with the issuance of this decision, the Administrator took actions aimed at increasing the level of security in the processing of personal data by A. (see point XII of the factual justification). In the opinion of the President of the UODO, the execution of the aforementioned actions should be regarded as a mitigating circumstance influencing the reduction of the imposed penalty.

Other circumstances, as indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified violation in this case, were deemed neutral by the President of the UODO, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. Actions taken to minimize the damage suffered by the individuals whose data were involved (Article 83(2)(c) of Regulation 2016/679). In the context of this criterion, the purpose of the Administrator's action, which is to minimize the damage suffered by the individuals whose data are involved, is significant. The President of the UODO did not record any such actions taken by the Administrator in this case. Merely informing the individuals whose data were disclosed about the incident cannot be considered an action aimed at minimizing the damage suffered by these individuals.

2. The degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The findings made by the President of the UODO allow for the conclusion that the Administrator, despite having a contract with the Data Processor, having adopted appropriate internal regulations, and having knowledge regarding the implementation of changes in information systems, did not fulfill his obligations.

****1. Scope of supervision over the Data Processor****

During the implementation of changes in the IT system used for processing personal data, which consequently led to freedom in the actions of the Data Processor, i.e., making changes in the IT system without prior appropriate testing of the applied security measures in the testing phase of the implemented solution. The lack of any supervision over the process of implementing changes in the IT system, in which personal data was processed, results in a high degree of responsibility of the Administrator for the breach of confidentiality of personal data. In this case, this circumstance constitutes the essence of the breach of the provisions of Regulation 2016/679; it is not merely a factor influencing – mitigating or aggravating – its assessment. For this reason, the lack of appropriate technical and organizational measures, referred to in Articles 25 and 32 of Regulation 2016/679, cannot be considered by the President of the UODO in this case as a circumstance that could additionally influence a stricter assessment of the breach and the amount of the administrative fine imposed on A.

****2. The manner in which the supervisory authority became aware of the breach (Article 83(2)(h) of Regulation 2016/679)****

The President of the UODO identified a breach of the provisions of Regulation 2016/679 as a result of a report of a personal data breach made by the Administrator. By making this report, the Administrator was merely fulfilling a legal obligation, and there are no grounds to consider that this circumstance constitutes a mitigating factor. According to Guidelines 04/2022, "(...) when assessing this aspect, particular importance can be attributed to the question of whether the administrator or the data processor notified of the breach on their own initiative, and if so, to what extent, before the supervisory authority was informed of the breach through – for example – a complaint or investigation. This

circumstance is irrelevant when the administrator is subject to specific obligations regarding the reporting of breaches (such as the obligation to report a personal data breach specified in Article 33). In such cases, the fact of making a report should be considered a neutral circumstance (...)."

****3. Compliance with previously applied measures in the same case, referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679)****

Before issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the Administrator in the case under consideration, which means that the Administrator had no obligation to take any actions related to their application, which actions, when assessed by the President of the UODO, could have a burdensome or mitigating effect on the assessment of the identified breach.

****4. Application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679)****

The Administrator does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not – as stipulated by the provisions of Regulation 2016/679 – mandatory for administrators and data processors, which is why the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.

****5. Financial benefits obtained directly or indirectly in connection with the breach or losses avoided (Article 83(2)(k) of Regulation 2016/679)****

The President of the UODO did not find that the Administrator obtained any financial benefits or avoided such losses in connection with the breach. Therefore, there are no grounds to treat this circumstance as aggravating for the Administrator. The establishment of measurable financial benefits resulting from the breach of the provisions of Regulation 2016/679 should be assessed very negatively. However, the lack of such benefits for the administrator, as a natural state independent of the breach and its effects, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" – that occurred on the part of the entity committing the breach.

****6. Other aggravating or mitigating factors (Article 83(2)(k) of Regulation 2016/679)****

The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could influence the assessment of the breach and the amount of the imposed administrative fine. In the opinion of the President of the UODO, the administrative fine imposed fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportionate, and deterrent in this individual case. Considering all the circumstances discussed above, the President of the UODO concluded that the imposition of an administrative fine on the Administrator is necessary and justified by the gravity, nature, and scope of the alleged breaches of the provisions of Regulation 2016/679. It should be noted that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679 against this entity, especially merely issuing a reprimand, would not suffice. 58 para. 2 lit. b) of Regulation 2016/679), it would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the aforementioned entity would not commit similar negligence in the future as in the present case.

Pursuant to Article 103 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the u.o.d.o., the equivalent amounts expressed in euros mentioned in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate

announced in the nearest exchange rate table of the National Bank of Poland after that date.

In light of the above, the President of UODO, based on Article 83 para. 4 lit. a) in connection with Article 103 of the u.o.d.o., imposed on A. - using the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) - an administrative monetary penalty in the amount of 1,527,855.00 PLN (which constitutes the equivalent of 350,000 EUR).

In the opinion of the President of UODO, the imposed monetary penalty of 1,527,855.00 PLN (in words: one million five hundred twenty-seven thousand eight hundred fifty-five zlotys) meets the criteria referred to in Article 83 para. 1 of Regulation 2016/679 due to the seriousness of the identified violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. Referring to the amount of the administrative monetary penalty imposed on A., the President of UODO considered it proportional to the financial situation of the Administrator and that it would not constitute an excessive burden for him.

According to the "Report (...)" presented by the Administrator, the total annual turnover from the previous financial year, i.e., in 2023, amounted to (...) PLN, which means that the amount of the administrative monetary penalty imposed in this case constitutes approximately (...) % of the aforementioned revenue. At the same time, it is worth emphasizing that the amount of the imposed penalty is only about 1.75% of the maximum penalty amount that the President of UODO could - in accordance with Article 83 para. 5 of Regulation 2016/679, applying the static maximum penalty of up to 20,000,000 EUR - impose on A. for the violations identified in this case.

The amount of the penalty has been set at such a level that, on the one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, it does not create a situation in which the necessity to pay the financial penalty would lead to negative consequences, such as a significant reduction in employment or a substantial drop in A.'s turnover. In the opinion of the President of UODO, A. should and is capable of bearing the consequences of his negligence in the area of data protection, as evidenced by the "Report (...)".

Moreover, in determining the amount of the penalty, the supervisory authority took into account the financial situation of the Administrator at the time of issuing this administrative decision, i.e., the fact that in (...) A. was undergoing proceedings regarding (...), and since June 11, 2024, it has been undergoing (...).

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of UODO categorized the violations of the provisions of Regulation 2016/679 identified in this case (see Chapter 4.1 of Guidelines 04/2022). The violations of personal data protection regulations identified in this case fall into both categories of violations subject to a penalty of up to 10,000,000 EUR, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable, as well as to the category of violations subject to a penalty of up to 20,000,000 EUR, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable. The most serious violation identified in this case, i.e., the violation of Article 5 para. 1 lit. f) and para. 2 of Regulation 2016/679 - pursuant to Article 83 para. 5 lit. a) of Regulation 2016/679 - is subject to an administrative monetary penalty of up to 20,000,000 EUR, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable. It has therefore been considered in abstracto (in isolation from the individual circumstances of the specific case) by the EU legislator as more serious than the violations indicated in Article 83 para. 4 of Regulation 2016/679.

2. The President of UODO assessed the violations identified in this case as violations of a high level of

seriousness (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria among those listed in Article 83 para. 2 of Regulation 2016/679 that relate to the subject matter of the violations (constituting the "seriousness" of the violation) were taken into account, namely: the nature, gravity, and duration of the violations (Article 83 para. 2 lit. a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83 para. 2 lit. b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83 para. 2 lit. g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted here that considering their combined impact on the assessment of the violations identified in this case... the severity of the violations presented in point 60 of the Guidelines 04/2022. Consequently, it is accepted that the starting amount for calculating the fine is a value within the range of 20% to 100% of the maximum fine that can be imposed on A. Considering that Article 83(5) of Regulation 2016/679 obliges the President of the UODO to adopt a maximum fine for the violations indicated in this provision of 20,000,000 EUR or, if this amount is higher than 20,000,000 EUR, an amount equal to 4% of A's turnover from the previous financial year, the President of the UODO concluded that the so-called static maximum fine amount, i.e., 20,000,000 EUR, applies in this case. Having a range from 0 to 20,000,000 EUR at his disposal, the President of the UODO accepted, as adequate and justified by the circumstances of the case, a starting amount for calculating the fine of 10,000,000 EUR (which constitutes 50% of the static maximum fine).

3. In accordance with point 66 of the Guidelines 04/2022 (regarding enterprises with an annual turnover between 10,000,000 EUR and 50,000,000 EUR), the President of the UODO deemed it appropriate to utilize the option of reducing the starting amount based on the assessment of the severity of the violation to an amount of 500,000 EUR.

4. The President of the UODO assessed the impact of other circumstances (besides those considered above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of the Guidelines 04/2022) on the established violation. These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by the Guidelines 04/2022 – to the subjective side of the violation, namely to the entity that is the perpetrator of the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The President of the UODO concluded (which was justified in the above-presented part of the decision's reasoning) that the aggravating circumstances in this case, and thus additionally increasing the extent of the penalty imposed by this decision, are the relevant previous violations identified by the President of the UODO on the part of A. (Article 83(2)(e) of Regulation 2016/679). Conversely, the circumstances having a mitigating effect on the amount of the monetary penalty are the degree of cooperation with the supervisory authority to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The remaining factors (from Article 83(2)(c), (d), (h), (i), (j), (k) of Regulation 2016/679) – as indicated above – had no impact, either mitigating or aggravating, on the assessment of the violation and consequently on the extent of the penalty. Due to the existence of additional aggravating and mitigating circumstances related to the subjective side of the violations, the President of the UODO deemed it appropriate to maintain the monetary penalty at the amount of 500,000 EUR.

5. The President of the UODO stated that the amount of the administrative monetary penalty determined in the manner presented above does not exceed – according to Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the penalty provided for the most serious violation (see Chapter 6 of the Guidelines 04/2022).

6. Despite the fact that the amount of the penalty determined according to the above principles does not exceed the legally defined maximum penalty, the President of the UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for penalty assessment (see Chapter 7 of the Guidelines 04/2022). Undoubtedly, a monetary penalty of 500,000 EUR would be an effective penalty (due to its severity, it would achieve its repressive goal, which is to punish unlawful behavior) and

deterrent (effectively discouraging both A. and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, considering the current financial condition of the Administrator (i.e., the fact that (...)), such a penalty would, in the opinion of the President of the UODO, be disproportionate both in relation to the severity of the identified violations (which is low in both abstracto and in concreto – see points 1 and 2 above) and due to its excessive severity in relation to that weight. The principle of proportionality requires, among other things, that the measures adopted by the administrative authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of the Guidelines 04/2022). In other words: “A sanction is proportional if it does not exceed the threshold of severity determined by considering the circumstances of the specific case” (P. Litwiński (ed.), Regulation of the European Parliament and Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected sectoral provisions. Commentary). Therefore, taking into account the proportionality of the penalty, the President of the UODO further reduced its amount – to 350,000 EUR (equivalent to 1,527,855.00 PLN). In his opinion, such determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which further increases in the penalty amount will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the penalty amount could occur at the expense of its effectiveness and deterrent nature, as well as a coherent understanding – in relation to other supervisory authorities and the EROD – of the severity of the violations.

****Application and Enforcement of Regulation 2016/679****

****and Principles of Equal Treatment of Entities in the EU and EEA Internal Market.****

In summary, in the opinion of the President of the UODO, the administrative fine imposed in this case on the Administrator meets, in light of the overall individual circumstances of the case, the criteria (functions of penalties) referred to in Article 83(1) of Regulation 2016/679, due to the seriousness of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 – especially the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679 and the principle of accountability referred to in Article 5(2) of Regulation 2016/679.

****VI. b) Justification for the Imposition and Determination of the Amount of the Administrative Fine on X.****

In deciding to impose an administrative fine on X., the President of the UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which have a detrimental impact on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679).

In this case, a violation by the Data Processor of the provisions of Articles 32(1) and (2) and Articles 32(1) and (2) in connection with Article 28(3)(c) and (f) of Regulation 2016/679 was identified. The violation of the aforementioned provisions was related to an event involving the disclosure of a wide range of personal data of A.'s clients. When imposing the fine, the circumstance that the violation of the provisions of Regulation 2016/679, which imposes obligations on the Data Processor regarding the application of appropriate technical and organizational measures to ensure the security of the processed personal data, affected the confidentiality breach of over 21,000 clients of the Administrator was of significant importance. It thus has considerable weight and serious character, as it may lead to material or non-material damages for the individuals whose data has been violated, and the likelihood of their occurrence is high.

Furthermore, the risk arising from the wide range of data covered by the breach, the large number of data subjects, as well as the large scale and professional nature of the data processing must also be taken into account. It should be emphasized that there remains a high risk of unlawful use of the personal data of the individuals whose data has been breached, as the purpose for which

unauthorized persons obtained the file containing the Administrator's client database is unknown. Therefore, the individuals concerned may still suffer material damage, and the mere breach of data confidentiality also constitutes non-material damage (harm). The data subject may at least feel fear of losing control over their personal data, identity theft, or identity fraud, or finally, fear of financial loss. As indicated by the District Court in Warsaw in its judgment of August 6, 2020, case no. XXV C 2596/19, fear, and thus loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of *Natsionalna agentsia za prihodite* (C-340/21) emphasized that "Article 82(1) of the GDPR must be interpreted as meaning that the fear of potential misuse of personal data by third parties, which a data subject experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

The President of the UODO also considers the long duration of the violation of Regulation 2016/679 by X. as an aggravating circumstance. In the case of the violation of Article 28(1) of Regulation 2016/679, it should be assumed that the violation lasted from the date of the conclusion of the data processing agreement (July 31, 2019) until the date of the termination of services provided by X. to A. (September 30, 2020). In the case of the violation of the other provisions of Regulation 2016/679, it should be noted that it lasted from the date of the commencement of cooperation between A. and X. (July 31, 2019) until the date of the implementation of technical and organizational measures aimed at ensuring security in the process of personal data processing, the implementation of which the Administrator declared only after the occurrence of the personal data breach in a letter dated June 3, 2020.

2. The unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). The Data Processor was aware that in the case of allowing the processing of personal data in IT systems, it should process personal data in such a way as to ensure appropriate security, which is mandated by Article 32(1) and (2) of Regulation 2016/679. X., due to the nature of its business activity, should have been aware of the necessity to fulfill the obligation to provide sufficient guarantees for the implementation of appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679.

It should be emphasized at this point that the occurrence of the subject violation was contributed to by improper communication between the Administrator and the Data Processor. Evidence of improper communication between the aforementioned entities is the fact that during the course of these proceedings, A. and X. mutually shifted responsibility for the event in question. Although it is the Administrator who is primarily responsible...

****1. Responsibility for the implementation of adequate security measures in the processing of personal data****

However, this does not change the fact that the long-term cooperation between the Administrator and the Processor, as well as the fact of performing an additional task (transferring the website to a new environment), requires additional cooperation of the Processor with the Administrator. The Processor, despite being aware of the security threat in the process of processing personal data, did not take additional actions in this regard, and during the administrative proceedings, attempted to shift the responsibility for the breach of personal data protection onto the Administrator, forgetting that it also bears certain obligations regarding the implementation of appropriate technical and organizational measures to secure personal data. The Processor did not independently conduct a risk analysis for the process related to the transfer of the website to a new environment and did not take into account that the transferred website contained personal data. Thus, X. unintentionally violated the provisions on personal data protection – Article 32(1) and (2) and Article 32(1) and (2) in connection with Article 28(3)(c) and (f) of Regulation 2016/679.

****3. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679)****

The personal data affected by the breach of the provisions of Regulation 2016/679 do not belong to the special categories of personal data referred to in Article 9 of Regulation 2016/679; however, their scope, i.e., name and surname, address of residence or stay, PESEL identification number, email address, phone number, encrypted password, is associated with a high risk of infringement of the

rights or freedoms of the natural persons affected by the breach. It should be emphasized that the fact that the breach involved personal data of such categories as the PESEL identification number along with the name and surname, which unequivocally identify a natural person, can realistically and negatively affect the protection of the rights or freedoms of that person. It should be noted that the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing, among other things, the date of birth and gender designation, is therefore closely related to the private sphere of the natural person and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679, is data of a special nature and requires such special protection.

In this context, it is worth recalling Guidelines 04/2022, which state: "Regarding the requirement to take into account the categories of personal data affected by the breach (Article 83(2)(g) [of Regulation 2016/679]), [Regulation 2016/679] clearly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 [of Regulation 2016/679] and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., data concerning location, data concerning private communication, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the greater the number of such categories of data affected by the breach or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The quantity of data concerning each data subject is also significant, as the amount of data concerning each data subject increases the scale of the infringement of the right to privacy and the protection of personal data."

This view was also shared by the aforementioned Court in the judgment of June 21, 2023, in case file II SA/Wa 150/23, where the Provincial Administrative Court in Warsaw stated: "In summary, the Court holds the position that the disclosure of the PESEL number indicates a high risk of infringement of the rights or freedoms of natural persons."

In determining the amount of the administrative monetary penalty, the President of the UODO took into account as a mitigating circumstance, which influenced the reduction of the imposed penalty, the good cooperation of the Processor with the supervisory authority undertaken and conducted to eliminate the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The Processor provided comprehensive answers to the supervisory authority's questions and, to the best of its ability, taking into account its role in the process of processing personal data, contributed to the elimination of the breach and the mitigation of its potential negative effects. In the opinion of the President of the UODO, the performance of the aforementioned activities should be considered a mitigating circumstance influencing the reduction of the imposed penalty. Other circumstances, indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the breach established in this case, were deemed by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

****1. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679)****

In the context of this criterion, the purpose of the Processor's actions, which is to minimize the damage suffered by the data subjects, is significant. The President of the UODO did not record any such actions by the Processor in this case.

****2. Degree of responsibility of the administrator****

with consideration of the technical and organizational measures implemented by him pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The findings made by the President of the Personal Data Protection Office (UODO) allow for the conclusion that the Data Processor, despite not receiving information from the Administrator that personal data is present on the transferred website, did not fulfill its obligations regarding the implementation of adequate security measures in the process

of personal data processing. The lack of proper communication between the Data Processor and the Administrator determines the necessity to conclude that X bears joint responsibility for the breach of personal data confidentiality.

In this case, this circumstance constitutes the essence of the breach of the provisions of Regulation 2016/679; it is not merely a factor influencing – either mitigating or aggravating – its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Article 32 of Regulation 2016/679 cannot be recognized by the President of UODO in this case as a circumstance that could additionally influence a stricter assessment of the breach and the amount of the administrative fine imposed on X.

On the other hand, regarding the obligations arising from Article 25 of Regulation 2016/679, it should be noted that they pertain to administrators, and therefore the discussed premise in this regard cannot be treated as aggravating or mitigating for the amount of the administrative fine imposed on the Data Processor.

3. Any relevant previous violations by the administrator or the Data Processor (Article 83(2)(e) of Regulation 2016/679). When making a decision on the imposition and amount of the administrative fine, the supervisory authority is obliged to pay attention to any previous violations of Regulation 2016/679. The EDPB in Guidelines 04/2022 explicitly states: “The existence of previous violations may be considered an aggravating factor when calculating the amount of the fine. The weight attributed to this factor should be determined taking into account the nature and frequency of previous violations. However, the absence of previous violations cannot be considered a mitigating circumstance, as compliance with the provisions of [Regulation 2016/679] is the norm.”

And although, as indicated in the aforementioned guidelines, “greater significance should be attributed to violations concerning the same subject matter, as they are closer to the violation that is the subject of the current proceedings, especially when the administrator or the Data Processor has previously committed the same violation (repeated violations)” (point 88 of the guidelines), all previous violations may constitute information about the overall approach of the administrator or the Data Processor to compliance with the provisions of Regulation 2016/679.

The President of UODO did not find any previous violations of personal data protection regulations committed by the Data Processor, which is why there are no grounds to treat this circumstance as aggravating. It is the obligation of every Data Processor to comply with the law (including personal data protection regulations), so the absence of previous violations cannot be a mitigating circumstance when imposing sanctions.

4. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of UODO identified the violation of the provisions of Regulation 2016/679 as a result of a report of a personal data breach made by the Administrator. However, this circumstance does not have an aggravating or mitigating character for determining the amount of the administrative fine imposed on the Data Processor, as the obligation to report a personal data breach was imposed on the Administrator, and it is he who bears responsibility for fulfilling this obligation.

5. Compliance with previously applied measures in the same case, referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Before issuing this decision, the President of UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the Data Processor in the case at hand, which is why the Data Processor had no obligation to take any actions related to their application, and such actions, subject to the assessment of the President of UODO, could have a burdensome or mitigating effect on the assessment of the identified violation.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Data Processor does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not – as stipulated by the provisions of Regulation 2016/679 –

mandatory for administrators and Data Processors, which is why the circumstance of their non-application cannot be considered against the Data Processor in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Data Processor.

7. Financial benefits obtained directly or indirectly in connection with the violation or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of UODO did not find that the Data Processor obtained any financial benefits or avoided any losses in connection with the violation.

****Types of Losses.**** There are no grounds for treating this circumstance as burdensome for the Data Processor. The determination of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed decidedly negatively. On the other hand, the failure of the Data Processor to achieve such benefits, as a natural state independent of the violation and its consequences, is a circumstance that, by its very nature, cannot be mitigating for the Data Processor. This is confirmed by the wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" - that is, those that occurred on the part of the entity committing the violation.

8. ****Other Burdening or Mitigating Factors (Article 83(2)(k) of Regulation 2016/679).**** The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative monetary penalty. In the opinion of the President of the UODO, the applied administrative monetary penalty fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case.

Taking into account all the circumstances discussed above, the President of the UODO concluded that the imposition of an administrative monetary penalty on the Data Processor is necessary and justified by the gravity, nature, and scope of the violations attributed to this entity under the provisions of Regulation 2016/679. It should be noted that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly limiting it to a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the aforementioned entity would not commit similar negligence in the future, as in this case.

Pursuant to the provisions of Article 103 of the Personal Data Protection Act, the equivalent amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in Polish zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Having the above in mind, the President of the UODO, based on Article 83(4)(a) in connection with Article 103 of the Personal Data Protection Act, for the violation described in the operative part of this decision, imposed on X. - applying the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) - an administrative monetary penalty in the amount of 20,037.00 PLN (which constitutes the equivalent of 4,590 EUR).

In the opinion of the President of the UODO, the imposed monetary penalty in the amount of 20,037.00 PLN (in words: twenty thousand thirty-seven zlotys) meets the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the identified violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. Referring to the amount of the administrative monetary penalty imposed on X., the President of the UODO considered that it is proportional to the financial situation of the Data Processor and will not constitute an excessive burden

for it.

From the information available on the website (...) "Report (...)", it follows that the net revenue from sales achieved by X. for the year 2023 amounted to (...) PLN. In connection with the above, the amount of the administrative monetary penalty imposed in this case constitutes approximately (...) % of the aforementioned revenue amount. At the same time, it is worth emphasizing that the amount of the imposed penalty is only about 0.05% of the maximum penalty amount that the President of the UODO could impose on X. for the violations identified in this case, applying the static maximum penalty of up to 10,000,000 EUR in accordance with Article 83(4) of Regulation 2016/679.

The amount of the penalty was determined at such a level that, on the one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, while on the other hand, it does not create a situation in which the necessity to pay the financial penalty would lead to negative consequences, such as a significant reduction in employment or a substantial decrease in X.'s turnover.

In the opinion of the President of the UODO, X. should and is able to bear the consequences of its negligence in the area of data protection, as evidenced by the "Report (...)".

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the identified violations of the provisions of Regulation 2016/679 in this case (see Chapter 4.1 of Guidelines 04/2022). The violations identified in this case fall into the category of violations subject to a penalty of up to 10,000,000 EUR, and in the case of an enterprise - up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable.
2. The President of the UODO assessed the violations identified in this case as violations of a high level of seriousness (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria among those listed in Article 83(2) were taken into account.
2. The provisions of Article 83 of Regulation 2016/679, which pertain to the subject of the violations (constituting the "seriousness" of the violation), are as follows: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violations identified in this case leads to the conclusion that the level of their seriousness, also in concreto, is high (on the scale of seriousness of violations presented in point 60 of the Guidelines 04/2022). Consequently, the starting amount for calculating the fine is set within the range of 20% to 100% of the maximum fine that can be imposed on X. Given that Article 83(4) of Regulation 2016/679 obliges the President of the UODO to adopt a maximum fine for the violations indicated in this provision of 10,000,000 EUR or, if this amount is higher than 10,000,000 EUR, an amount equal to 2% of X's turnover from the previous financial year, the President of the UODO determined that the so-called static maximum fine amount of 10,000,000 EUR applies in this case. Having a range from 0 to 10,000,000 EUR at his disposal, the President of the UODO deemed an initial amount of 4,000,000 EUR (representing 40% of the static maximum fine) to be adequate and justified by the circumstances of the case.
3. In accordance with point 66 of the Guidelines 04/2022 (regarding enterprises with an annual turnover ranging from 0 EUR to 2,000,000 EUR), the President of the UODO found it appropriate to utilize the possibility of reducing the initial amount based on the assessment of the seriousness of the violation to the amount of 12,000 EUR.
4. The President of the UODO assessed the impact of other circumstances (besides those considered above in the assessment of the seriousness of the violation) indicated in Article 83(2) of Regulation

2016/679 (see Chapter 5 of the Guidelines 04/2022) on the identified violation. These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as the Guidelines 04/2022 assume – to the subjective side of the violation, that is, to the entity that committed the violation and its behavior before, during, and after the violation occurred. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The President of the UODO concluded (as justified in the above-presented part of the decision's reasoning) that the circumstances mitigating the amount of the monetary penalty include the degree of cooperation with the supervisory authority to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The remaining factors (from Article 83(2)(c), (d), (e), (h), (i), (j), (k) of Regulation 2016/679) – as indicated above – had no impact, either mitigating or aggravating, on the assessment of the violation and consequently on the imposition of the fine. Therefore, due to the existence of additional aggravating and mitigating circumstances concerning the subjective side of the violations, the President of the UODO deemed it appropriate to reduce the monetary penalty to the amount of 10,200 EUR.

5. The President of the UODO stated that the amount of the administrative monetary penalty determined in the manner presented above does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the penalty provided for the most serious violation (see Chapter 6 of the Guidelines 04/2022).

6. Despite the fact that the amount of the penalty determined according to the above principles does not exceed the legally defined maximum, the President of the UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for penalty imposition (see Chapter 7 of the Guidelines 04/2022). Undoubtedly, a monetary penalty of 10,200 EUR would be an effective penalty (due to its severity, it would achieve its repressive goal of punishing unlawful behavior) and deterrent (allowing effectively to dissuade both X and other processing entities from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be – in the opinion of the President of the UODO – disproportionate both in relation to the seriousness of the identified violations (which is high both in abstracto and in concreto – see points 1 and 2 above) and due to its excessive severity in relation to this seriousness. The principle of proportionality requires, among other things, that the measures adopted by the administrative authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of the Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected sectoral provisions. Commentary). Therefore, taking into account the proportionality of the penalty, the President of the UODO further reduced the amount of the penalty to 4,590.00 EUR (equivalent to 20,037 PLN). In his opinion, such a determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which further increases in the penalty amount will not be associated with an increase in its effectiveness and deterrent effect.

character. On the other hand, a greater reduction in the amount of the fine could occur at the expense of its effectiveness and deterrent character, as well as a coherent understanding, application, and enforcement of Regulation 2016/679 in relation to other supervisory authorities and the EDPB, as well as the principle of equal treatment of entities in the EU and EEA internal market.

In summary, in the opinion of the President of the UODO, the administrative monetary penalty imposed in this case on the Data Processor meets, in light of the overall individual circumstances of the case, the criteria (functions of penalties) referred to in Article 83(1) of Regulation 2016/679, due to the seriousness of the identified violations in the context of the fundamental requirements of Regulation 2016/679.

Taking the above into account, the President of the UODO has decided as stated in the operative part

of this decision.

[1] https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-072020-concepts-controller-and-processor-gdpr_en

[2] https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_en

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-11-12

Information entered by:

Wioletta Golańska

2024-11-20 10:15:09

Last modified by:

Karolina Jastalska

2024-12-23 11:17:19